Fortify Security Report

Jul 19, 2016

MHussaini

Executive Summary

Issues Overview

On Jul 19, 2016, a source code review was performed over the epds-auth code base. 98 files, 2,400 LOC (Executable) were scanned and reviewed for defects that could lead to potential security vulnerabilities. A total of 29 reviewed findings were uncovered during the analysis.

Issues by Fortify Priority Order

High	18
Critical	11

Recommendations and Conclusions

The Issues Category section provides Fortify recommendations for addressing issues at a generic level. The recommendations for specific fixes can be extrapolated from those generic recommendations by the development group.

Project Summary

Code Base Summary

Code location: C:/AmersFiles/Gitworkspace/epds-auth
Number of Files: 98
Lines of Code: 2400
Build Label: epds-auth

Scan Information

Scan time: 01:21
SCA Engine version: 6.30.0086
Machine Name: AIOCOFT55000042
Username running scan: MHussaini

Results Certification

Results Certification Valid

Details:

Results Signature:

SCA Analysis Results has Valid signature

Rules Signature:

There were no custom rules used in this scan

Attack Surface

Attack Surface:
Command Line Arguments:
gov.gao.epds.auth.test.JavaCodeTester.main
gov.gao.epds.auth.test.MethodTester.main
gov.gao.epds.auth.test.TokenTester.main
gov.gao.epds.auth.utils.AccountLockUtil.main
gov.gao.epds.auth.utils.PwdValidator.main
gov.gao.epds.passwordutils.Test.main
gov.gao.epds.tokenutils.TokenTester.main

Private Information:
null.null.null
java.util.Properties.getProperty
javax.crypto.SecretKeyFactory.generateSecret

Java Properties:
java.lang.System.getProperty
java.util.Properties.load

System Information:
null.null.null

java.lang.ClassLoader.getResource
java.lang.Throwable.getMessage
java.net.InetAddress.getLocalHost
java.net.URISyntaxException.getMessage
org.codehaus.jackson.JsonProcessingException.getMessage
org.codehaus.jackson.map.JsonMappingException.getMessage

Filter Set Summary

Current Enabled Filter Set:
Quick View

Filter Set Details:

Folder Filters:
If [fortify priority order] contains critical Then set folder to Critical
If [fortify priority order] contains high Then set folder to High
If [fortify priority order] contains medium Then set folder to Medium
If [fortify priority order] contains low Then set folder to Low
Visibility Filters:
If impact is not in range [2.5, 5.0] Then hide issue
If likelihood is not in range (1.0, 5.0] Then hide issue

Audit Guide Summary

Audit guide not enabled

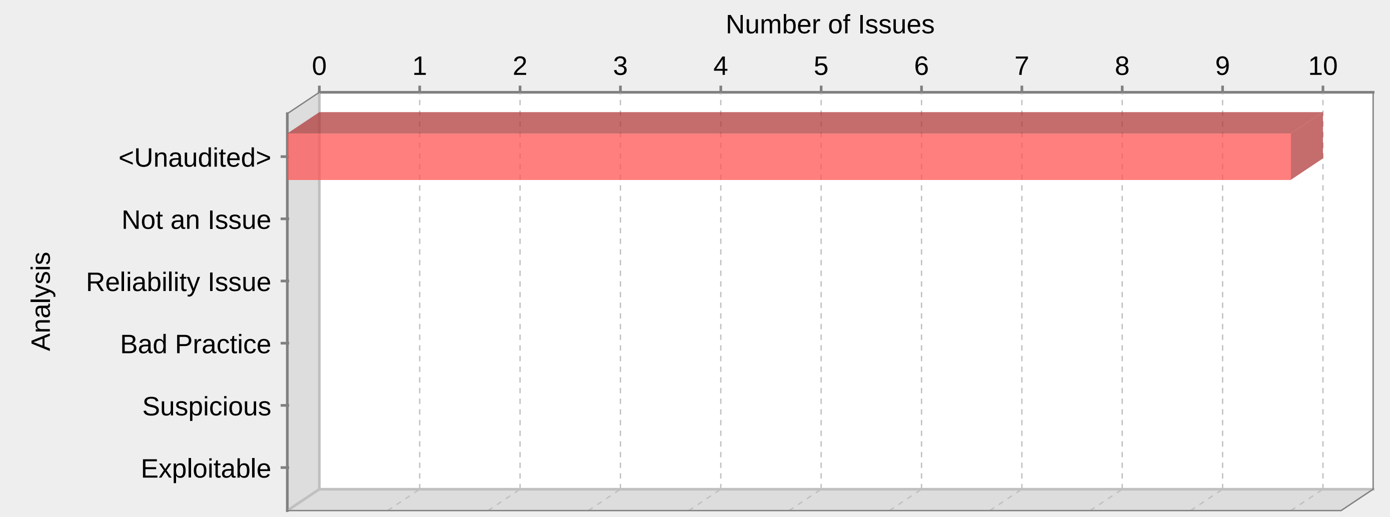
Results Outline

Overall number of results

The scan found 29 issues.

Vulnerability Examples by Category

Category: Privacy Violation (10 Issues)



Explanation:

Privacy violations occur when:

1. Private user information enters the program.

2. The data is written to an external location, such as the console, file system, or network.

Example 1: The following code contains a logging statement that tracks the contents of records added to a database by storing them in a log file. Among other values that are stored, the getPassword() function returns the user-supplied plaintext password associated with the account.

```
pass = getPassword();
...
dbmsLog.println(id+":"+pass+":"+type+":"+tstamp);
```

The code in the example above logs a plaintext password to the filesystem. Although many developers trust the filesystem as a safe storage location for data, it should not be trusted implicitly, particularly when privacy is a concern.

Privacy is one of the biggest concerns in the mobile world for a couple of reasons. One of them is a much higher chance of device loss. The other has to do with inter-process communication between mobile applications. The essence of mobile platforms is applications that are downloaded from various sources and run alongside each other on the same device. The likelihood of running a piece of malware next to a banking application is high, which is why application authors need to be careful about what information they include in messages addressed to other applications running on the device. Sensitive information should never be part of inter-process communication between mobile applications.

Example 2: The code below reads username and password for a given site from an Android WebView store and broadcasts them to all the registered receivers.

```
...
webview.setWebViewClient(new WebViewClient() {
public void onReceivedHttpAuthRequest(WebView view,
HttpAuthHandler handler, String host, String realm) {
String[] credentials = view.getHttpAuthUsernamePassword(host, realm);
String username = credentials[0];
String password = credentials[1];
Intent i = new Intent();
i.setAction("SEND_CREDENTIALS");
i.putExtra("username", username);
i.putExtra("password", password);
```

```
view.getContext().sendBroadcast(i);
}
});
...
```

There are several problems with this example. First of all, by default, WebView credentials are stored in plaintext and are not hashed. So if a user has a rooted device (or uses an emulator), she is able to read stored passwords for given sites. Second, plaintext credentials are broadcast to all the registered receivers, which means that any receiver registered to listen to intents with the SEND_CREDENTIALS action will receive the message. The broadcast is not even protected with a permission to limit the number of recipients, even though in this case, we do not recommend using permissions as a fix.

Private data can enter a program in a variety of ways:

- Directly from the user in the form of a password or personal information

- Accessed from a database or other data store by the application

- Indirectly from a partner or other third party

Typically, in the context of the mobile world, this private information would include (along with passwords, SSNs and other general personal information):

- Location

- Cell phone number

- Serial numbers and device IDs

- Network Operator information

- Voicemail information

Sometimes data that is not labeled as private can have a privacy implication in a different context. For example, student identification numbers are usually not considered private because there is no explicit and publicly-available mapping to an individual student's personal information. However, if a school generates identification numbers based on student social security numbers, then the identification numbers should be considered private.

Security and privacy concerns often seem to compete with each other. From a security perspective, you should record all important operations so that any anomalous activity can later be identified. However, when private data is involved, this practice can create risk.

Although there are many ways in which private data can be handled unsafely, a common risk stems from misplaced trust. Programmers often trust the operating environment in which a program runs, and therefore believe that it is acceptable to store private information on the file system, in the registry, or in other locally-controlled resources. However, even if access to certain resources is restricted, this does not guarantee that the individuals who do have access can be trusted. For example, in 2004, an unscrupulous employee at AOL sold approximately 92 million private customer e-mail addresses to a spammer marketing an offshore gambling web site [1].

In response to such high-profile exploits, the collection and management of private data is becoming increasingly regulated. Depending on its location, the type of business it conducts, and the nature of any private data it handles, an organization may be required to comply with one or more of the following federal and state regulations:

- Safe Harbor Privacy Framework [3]

- Gramm-Leach Bliley Act (GLBA) [4]

- Health Insurance Portability and Accountability Act (HIPAA) [5]

- California SB-1386 [6]

Despite these regulations, privacy violations continue to occur with alarming frequency.

Recommendations:

When security and privacy demands clash, privacy should usually be given the higher priority. To accomplish this and still maintain required security information, cleanse any private information before it exits the program.

To enforce good privacy management, develop and strictly adhere to internal privacy guidelines. The guidelines should specifically describe how an application should handle private data. If your organization is regulated by federal or state law, ensure that your privacy guidelines are sufficiently strenuous to meet the legal requirements. Even if your organization is not regulated, you must protect private information or risk losing customer confidence.

The best policy with respect to private data is to minimize its exposure. Applications, processes, and employees should not be granted access to any private data unless the access is required for the tasks that they are to perform. Just as the principle of least privilege dictates that no operation should be performed with more than the necessary privileges, access to private data should be restricted to the smallest possible group.

For mobile applications, make sure they never communicate any sensitive data to other applications running on the device. When private data needs to be stored, it should always be encrypted. For Android, as well as any other platform that uses SQLite database, a good option is SQLCipher -- an extension to SQLite database that provides transparent 256-bit AES encryption of database files. Thus, credentials can be stored in an encrypted database.

Example 3: The code below demonstrates how to integrate SQLCipher into an Android application after downloading the necessary binaries, and store credentials into the database file.

```
import net.sqlcipher.database.SQLiteDatabase;
...
SQLiteDatabase.loadLibs(this);
File dbFile = getDatabasePath("credentials.db");
dbFile.mkdirs();
dbFile.delete();
SQLiteDatabase db = SQLiteDatabase.openOrCreateDatabase(dbFile, "credentials", null);
db.execSQL("create table credentials(u, p)");
db.execSQL("insert into credentials(u, p) values(?, ?)", new Object[]{username, password});
...
```

Note that references to android.database.sqlite.SQLiteDatabase are substituted with those of net.sqlcipher.database.SQLiteDatabase.

To enable encryption on the WebView store, WebKit has to be re-compiled with the sqlcipher.so library.

Example 4: The code below reads username and password for a given site from an Android WebView store and instead of broadcasting them to all the registered receivers, it only broadcasts internally so that the broadcast can only be seen by other parts of the same app.

```
...
webview.setWebViewClient(new WebViewClient() {
public void onReceivedHttpAuthRequest(WebView view,
HttpAuthHandler handler, String host, String realm) {
String[] credentials = view.getHttpAuthUsernamePassword(host, realm);
String username = credentials[0];
String password = credentials[1];
Intent i = new Intent();
i.setAction("SEND_CREDENTIALS");
i.putExtra("username", username);
i.putExtra("password", password);
LocalBroadcastManager.getInstance(view.getContext()).sendBroadcast(i);
}
});
...
```

Tips:

1. As part of any thorough audit for privacy violations, ensure that custom rules have been written to identify all sources of private or otherwise sensitive information entering the program. Most sources of private data cannot be identified automatically. Without custom rules, your check for privacy violations is likely to be substantially incomplete.

2. The Fortify Java Annotations FortifyPassword, FortifyNotPassword, FortifyPrivate and FortifyNotPrivate can be used to indicate which fields and variables represent passwords and private data.

3. A number of modern web frameworks provide mechanisms for performing validation of user input. Struts and Spring MVC are among them. To highlight the unvalidated sources of input, the HPE Security Fortify Secure Coding Rulepacks dynamically re-prioritize the issues reported by HPE Security Fortify Static Code Analyzer by lowering their probability of exploit and providing pointers to the supporting evidence whenever the framework validation mechanism is in use. We refer to this feature as Context-Sensitive Ranking. To further assist the HPE Security Fortify user with the auditing process, the HPE Security Fortify Software Security Research group makes available the Data Validation project template that groups the issues into folders based on the validation mechanism applied to their source of input.

4. Fortify RTA adds protection against this category.

AuthenticationService.java, line 453 (Privacy Violation)

Fortify Priority:	Critical	**Folder**	Critical
Kingdom:	Security Features		

Abstract: The method resetUserAccount() in AuthenticationService.java mishandles confidential information, which can compromise user privacy and is often illegal.

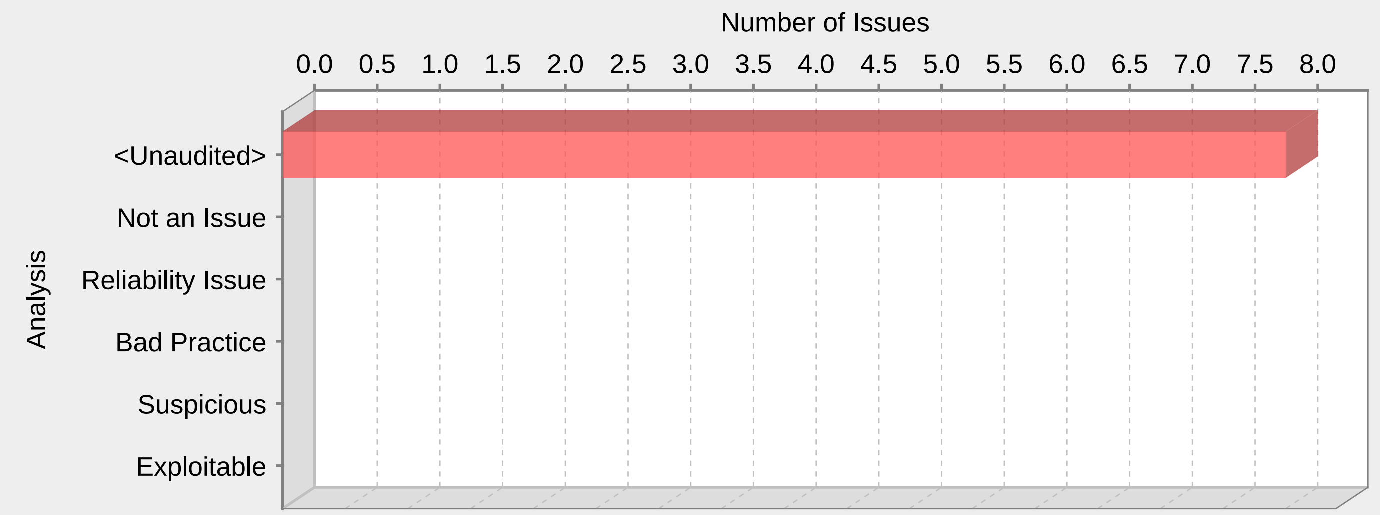
Source: User_info.java:230 Read password()

```
228
229   public void setPassword(String password) {
230    this.password =******
231   }
```

Sink: AuthenticationService.java:453 Return serviceResponse()

```
451    ServiceResponse serviceResponse = userService.resetAccount(userId);
452
453    return serviceResponse;
454   }
455
```

Category: Privacy Violation: Heap Inspection (8 Issues)



Explanation:

Sensitive data (such as passwords, social security numbers, credit card numbers etc) stored in memory can be leaked if memory is not cleared after use. Often, Strings are used store sensitive data, however, since String objects are immutable, removing the value of a String from memory can only be done by the JVM garbage collector. The garbage collector is not required to run unless the JVM is low on memory, so there is no guarantee as to when garbage collection will take place. In the event of an application crash, a memory dump of the application might reveal sensitive data.

Example 1: The following code converts a password from a character array to a String.

```
private JPasswordField pf;
...
final char[] password = pf.getPassword();
...
String passwordAsString = new String(password);
```

This category was derived from the Cigital Java Rulepack. http://www.cigital.com/

Recommendations:

Always be sure to clear sensitive data when it is no longer needed. Instead of storing sensitive data in immutable objects like Strings, use byte arrays or character arrays that can be programmatically cleared.

Example 2: The following code clears memory after a password is used.

```
private JPasswordField pf;
...
final char[] password = pf.getPassword();
// use the password
...
// erase when finished
Arrays.fill(password, ' ');
```

Tips:

1. A number of modern web frameworks provide mechanisms for performing validation of user input. Struts and Spring MVC are among them. To highlight the unvalidated sources of input, the HPE Security Fortify Secure Coding Rulepacks dynamically re-prioritize the issues reported by HPE Security Fortify Static Code Analyzer by lowering their probability of exploit and providing pointers to the supporting evidence whenever the framework validation mechanism is in use. We refer to this feature as Context-Sensitive Ranking. To further assist the HPE Security Fortify user with the auditing process, the HPE Security Fortify Software Security Research group makes available the Data Validation project template that groups the issues into folders based on the validation mechanism applied to their source of input.

AuthenticationService.java, line 184 (Privacy Violation: Heap Inspection)

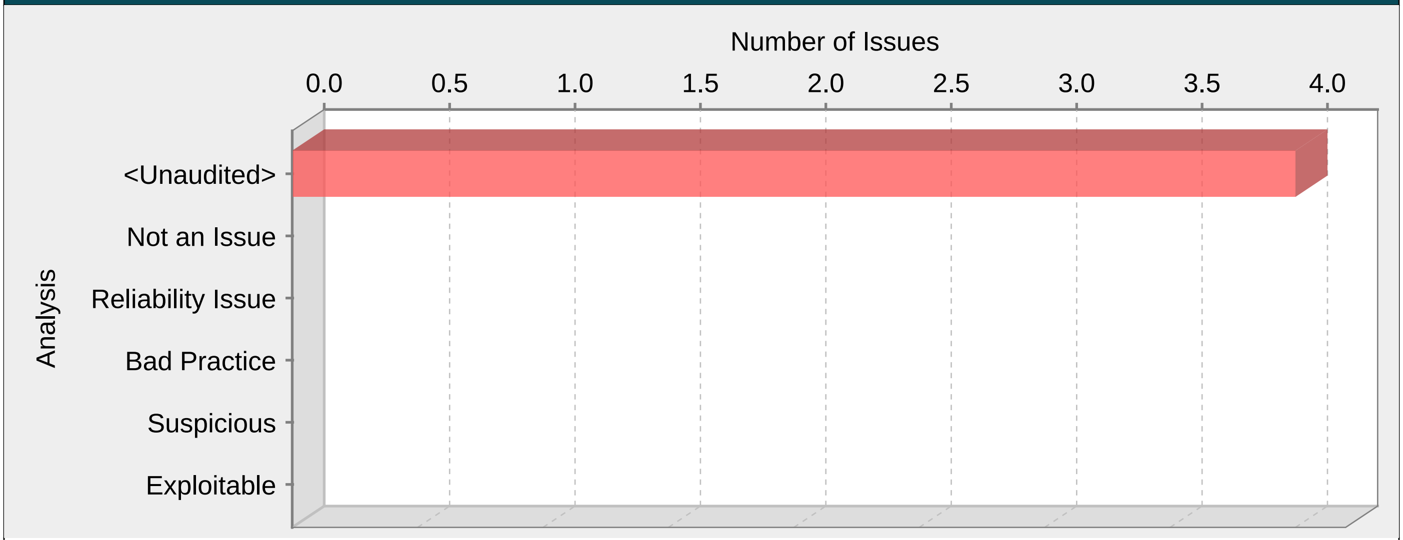
Fortify Priority:	High	**Folder**	High
Kingdom:	Security Features		
Abstract:	The method updatePasswordAndOrSecurityAnswers() in AuthenticationService.java stores sensitive data in a String object, making it impossible to reliably purge the data from memory.		
Source:	User_info_dto.java:288 Read this.password()		

```
286
287                 public String getPassword() {
288                  return password;
289                 }
```

Sink: AuthenticationService.java:184 java.lang.String.String()

```
182
183                  if (user_info_dto.getPassword() != null){
184                   final char[] password =****** String(Base64.decodeBase64(user_info_dto.getPassword()),
                "UTF-8").toCharArray();
185
186                   user_info_dto.setPassword(String.valueOf(password));
```

Category: Password Management: Empty Password in Configuration File (4 Issues)



Explanation:

It is never appropriate to use an empty string as a password. It is too easy to guess.

Recommendations:

Require that sufficiently hard-to-guess passwords protect all accounts and system resources. Consult the following references for help in establishing appropriate password guidelines.

Tips:

1. HPE Security Fortify Static Code Analyzer searches configuration files for common names used for password properties. Audit these issues by verifying that the flagged entry is used as a password.

epds.oireasd0108.properties, line 4 (Password Management: Empty Password in Configuration File)

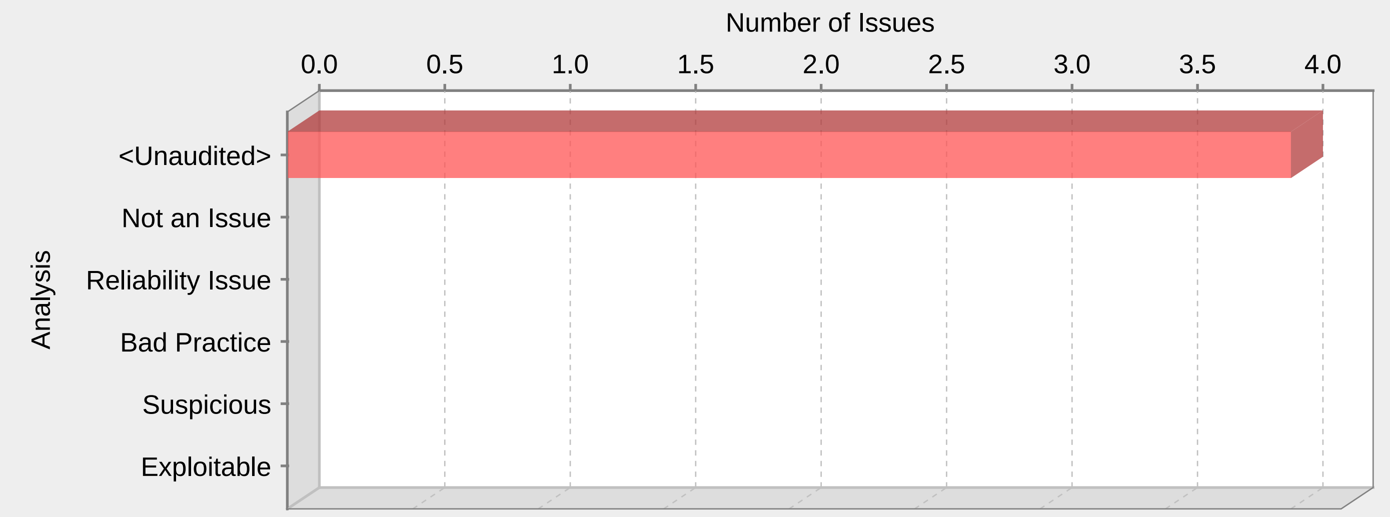
Fortify Priority:	High	**Folder**	High
Kingdom:	Environment		

Abstract: Using an empty string as a password is insecure.

Sink: epds.oireasd0108.properties:4 password()

```
2    port= 25
3    username=epds@gao.gov
4    password=
5    smtp.auth=false
6    smtp.starttls=false
```

Category: Password Management: Password in Configuration File (4 Issues)



Explanation:

Storing a plaintext password in a configuration file allows anyone who can read the file access to the password-protected resource. Developers sometimes believe that they cannot defend the application from someone who has access to the configuration, but this attitude makes an attacker's job easier. Good password management guidelines require that a password never be stored in plaintext.

Recommendations:

A password should never be stored in plaintext. Instead, the password should be entered by an administrator when the system starts. If that approach is impractical, a less secure but often adequate solution is to obfuscate the password and scatter the de-obfuscation material around the system so that an attacker has to obtain and correctly combine multiple system resources to decipher the password.

Some third-party products claim the ability to manage passwords in a more secure way. For example, WebSphere Application Server 4.x uses a simple XOR encryption algorithm for obfuscating values, but be skeptical about such facilities. WebSphere and other application servers offer outdated and relatively weak encryption mechanisms that are insufficient for security-sensitive environments. For a secure solution the only viable option is a proprietary one.

Tips:

1. HPE Security Fortify Static Code Analyzer searches configuration files for common names used for password properties. Audit these issues by verifying that the flagged entry is used as a password and that the password entry contains plaintext.

2. If the entry in the configuration file is a default password, require that it be changed in addition to requiring that it be obfuscated in the configuration file.

epds.local.properties, line 6 (Password Management: Password in Configuration File)

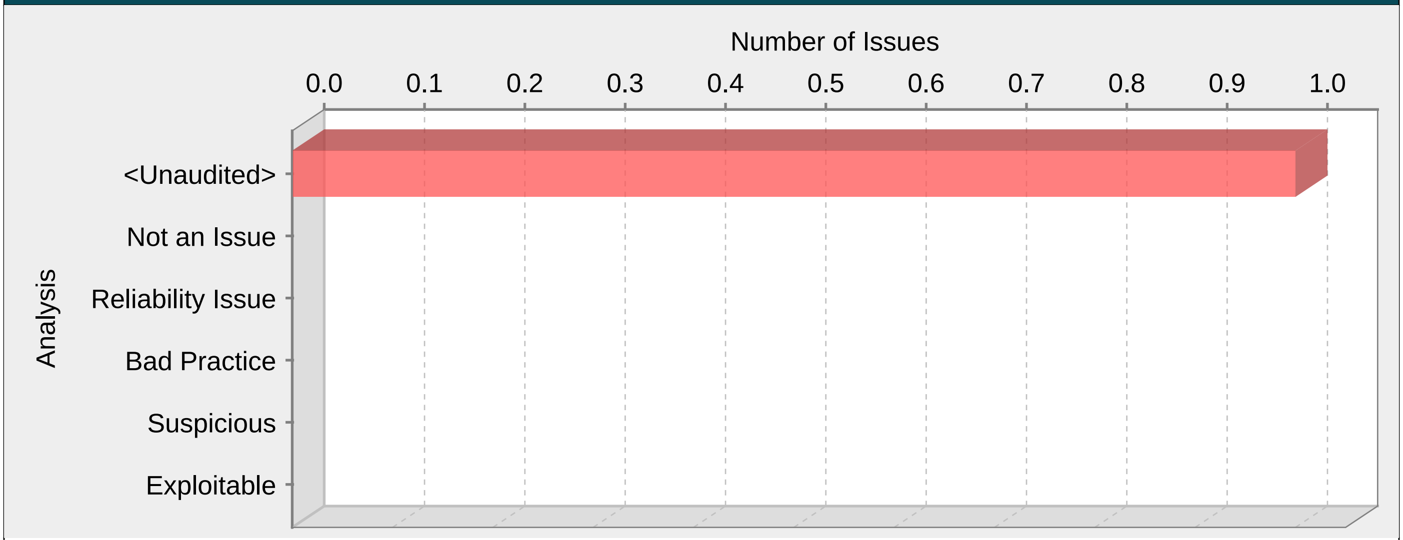
Fortify Priority:	High	**Folder**	High
Kingdom:	Environment		

Abstract: Storing a plaintext password in a configuration file may result in a system compromise.

Sink: epds.local.properties:6 password()

4	`#EPDS@GAO.GOV MAIL RELAY IS NOT ACCESSIBLE LOCALLY. THIS GMAIL ACCOUNT IS ONLY USED LOCALLY FOR TESTING EMAIL FUNCTIONALITY`
5	`username=epdssystem@gmail.com`
6	`password=******`
7	`smtp.auth=true`
8	`smtp.starttls=true`

Category: Insecure Transport: Mail Transmission (1 Issues)



Explanation:

Sensitive data sent over the wire unencrypted is subject to be read/modified by any attacker that can intercept the network traffic.

Example 1: The following Spring Mailer is NOT configured correctly to use SSL/TLS to communicate with an SMTP server:

```
<bean id="mailSender" class="org.springframework.mail.javamail.JavaMailSenderImpl">
<property name="host" value="smtp.acme.com" />
<property name="port" value="25" />
<property name="javaMailProperties">
<props>
<prop key="mail.smtp.auth">true</prop>
</props>
</property>
</bean>
```

Recommendations:

Most of the modern mail service providers offer encrypted alternatives on different ports that use SSL/TLS to encrypt all the data being sent over the wire or allow to upgrade an existing unencrypted connection to use SSL/TLS. Always use these alternatives when possible.

Example 2: The following Spring Mailer is properly configured to use SSL/TLS to communicate with an SMTP server:

```
<bean id="mailSender" class="org.springframework.mail.javamail.JavaMailSenderImpl">
<property name="host" value="smtp.acme.com" />
<property name="port" value="25" />
<property name="javaMailProperties">
<props>
<prop key="mail.smtp.auth">true</prop>
<prop key="mail.transport.protocol">smtps</prop>
<prop key="mail.smtp.socketFactory.port">465</prop>
<prop key="mail.smtp.socketFactory.class">javax.net.ssl.SSLSocketFactory</prop>
<prop key="mail.smtp.starttls.enable">true</prop>
</props>
</property>
</bean>
```

spring-context.xml, line 110 (Insecure Transport: Mail Transmission)

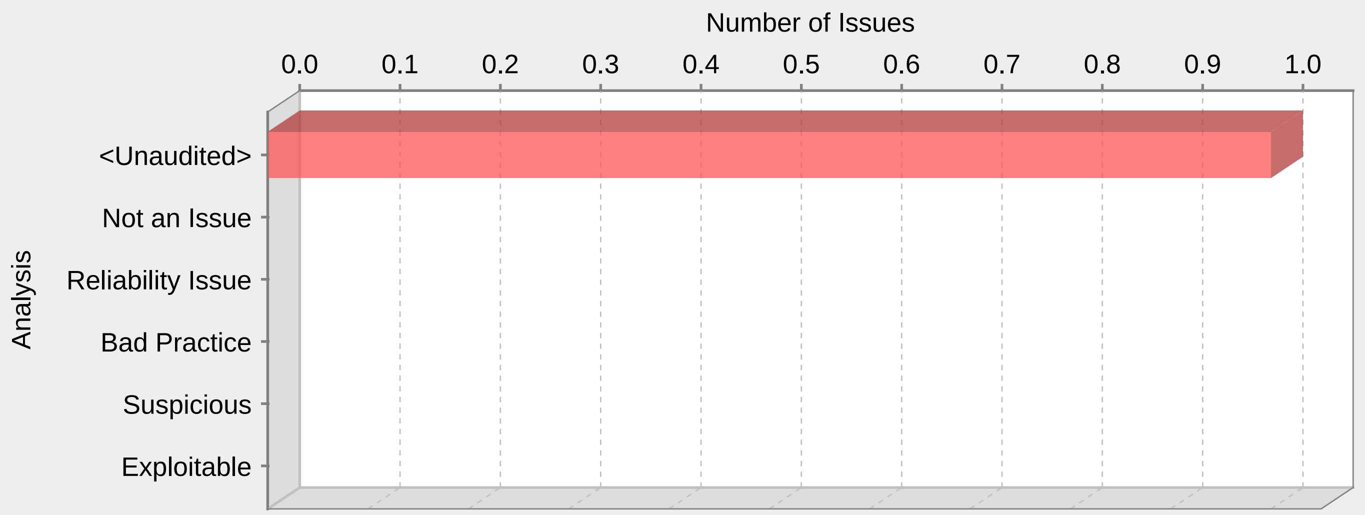
Fortify Priority:	Critical	**Folder**	Critical
Kingdom:	Security Features		
Abstract:	Establishing an unencrypted connection to a mail server allows an attacker to carry out a man-in-the-middle attack and read all the mail transmissions.		
Sink:	spring-context.xml:110 null()		

```
108    </bean>
```

```

    <bean id="mailSender" class="org.springframework.mail.javamail.JavaMailSenderImpl">
     <property name="host" value="${host}" />
     <property name="port" value="${port}" />
```

Category: Log Forging (1 Issues)



Explanation:

Log forging vulnerabilities occur when:

1. Data enters an application from an untrusted source.

2. The data is written to an application or system log file.

Applications typically use log files to store a history of events or transactions for later review, statistics gathering, or debugging. Depending on the nature of the application, the task of reviewing log files may be performed manually on an as-needed basis or automated with a tool that automatically culls logs for important events or trending information.

Interpretation of the log files may be hindered or misdirected if an attacker can supply data to the application that is subsequently logged verbatim. In the most benign case, an attacker may be able to insert false entries into the log file by providing the application with input that includes appropriate characters. If the log file is processed automatically, the attacker can render the file unusable by corrupting the format of the file or injecting unexpected characters. A more subtle attack might involve skewing the log file statistics. Forged or otherwise, corrupted log files can be used to cover an attacker's tracks or even to implicate another party in the commission of a malicious act [1]. In the worst case, an attacker may inject code or other commands into the log file and take advantage of a vulnerability in the log processing utility [2].

Example 1: The following web application code attempts to read an integer value from a request object. If the value fails to parse as an integer, then the input is logged with an error message indicating what happened.

```
...
String val = request.getParameter("val");
try {
int value = Integer.parseInt(val);
}
catch (NumberFormatException nfe) {
log.info("Failed to parse val = " + val);
}
...
```

If a user submits the string "twenty-one" for val, the following entry is logged:

INFO: Failed to parse val=twenty-one

However, if an attacker submits the string "twenty-one%0a%0aINFO:+User+logged+out%3dbadguy", the following entry is logged:

INFO: Failed to parse val=twenty-one

INFO: User logged out=badguy

Clearly, attackers can use this same mechanism to insert arbitrary log entries.

Some think that in the mobile world, classic web application vulnerabilities, such as log forging, do not make sense -- why would the user attack themself? However, keep in mind that the essence of mobile platforms is applications that are downloaded from various sources and run alongside each other on the same device. The likelihood of running a piece of malware next to a banking application is high, which necessitates expanding the attack surface of mobile applications to include inter-process communication.

Example 2: The following code adapts Example 1 to the Android platform.

```
...
String val = this.getIntent().getExtras().getString("val");
try {
int value = Integer.parseInt();
}
catch (NumberFormatException nfe) {
Log.e(TAG, "Failed to parse val = " + val);
}
...
```

Recommendations:

Prevent log forging attacks with indirection: create a set of legitimate log entries that correspond to different events that must be logged and only log entries from this set. To capture dynamic content, such as users logging out of the system, always use server-controlled values rather than user-supplied data. This ensures that the input provided by the user is never used directly in a log entry.

Example 1 can be rewritten to use a pre-defined log entry that corresponds to a NumberFormatException as follows:

```
...
public static final String NFE = "Failed to parse val. The input is required to be an integer value."
...
String val = request.getParameter("val");
try {
int value = Integer.parseInt(val);
}
catch (NumberFormatException nfe) {
log.info(NFE);
}
..
```

And here is an Android equivalent:

```
...
public static final String NFE = "Failed to parse val. The input is required to be an integer value."
...
String val = this.getIntent().getExtras().getString("val");
try {
int value = Integer.parseInt();
}
catch (NumberFormatException nfe) {
Log.e(TAG, NFE);
}
...
```

In some situations this approach is impractical because the set of legitimate log entries is too large or complicated. In these situations, developers often fall back on blacklisting. Blacklisting selectively rejects or escapes potentially dangerous characters before using the input. However, a list of unsafe characters can quickly become incomplete or outdated. A better approach is to create a whitelist of characters that are allowed to appear in log entries and accept input composed exclusively of characters in the approved set. The most critical character in most log forging attacks is the '\n' (newline) character, which should never appear on a log entry whitelist.

Tips:

1. Many logging operations are created only for the purpose of debugging a program during development and testing. In our experience, debugging will be enabled, either accidentally or purposefully, in production at some point. Do not excuse log forging vulnerabilities simply because a programmer says "I don't have any plans to turn that on in production".

2. A number of modern web frameworks provide mechanisms for performing validation of user input. Struts and Spring MVC are among them. To highlight the unvalidated sources of input, the HPE Security Fortify Secure Coding Rulepacks dynamically re-prioritize the issues reported by HPE Security Fortify Static Code Analyzer by lowering their probability of exploit and providing pointers to the supporting evidence whenever the framework validation mechanism is in use. We refer to this feature as Context-Sensitive Ranking. To further assist the HPE Security Fortify user with the auditing process, the HPE Security Fortify Software Security Research group makes available the Data Validation project template that groups the issues into folders based on the validation mechanism applied to their source of input.

TokenUtils.java, line 308 (Log Forging)

Fortify Priority:	High	**Folder**	High
Kingdom:	Input Validation and Representation		

Abstract: The method validateIpAddress() in TokenUtils.java writes unvalidated user input to the log on line 308. An attacker could take advantage of this behavior to forge log entries or inject malicious content into the log.

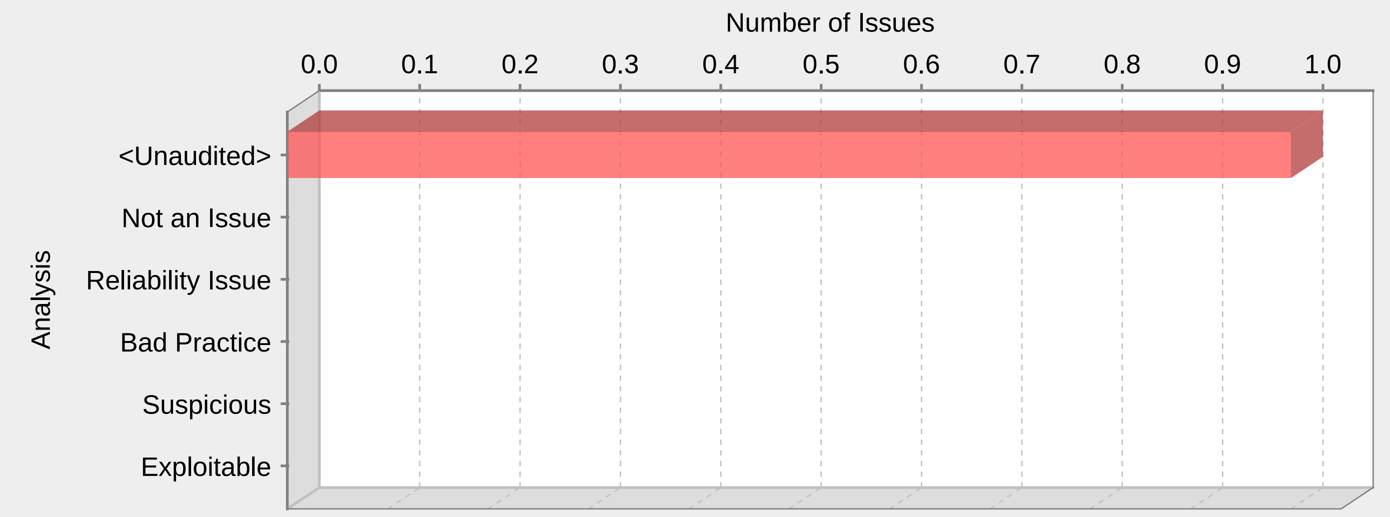
Source: AuthenticationService.java:329 validateToken(0)

```
327     @Path("/validate-token")
328     @Consumes("application/json")
329     public Response validateToken(ValidateToken validateToken) {
330
331      if (logger.isDebugEnabled()){
```

Sink: TokenUtils.java:308 org.slf4j.Logger.info()

```
306       String clientIp) {
307
308      logger.info("Validating token for remoteIp={}, IpAddressInsideToken ={}",clientIp, claimSet.getClaim("clientIp").toString());
309      String originalClientIp =  claimSet.getClaim("clientIp").toString();
310      return clientIp.equalsIgnoreCase(originalClientIp);
```

Category: Password Management: Hardcoded Password (1 Issues)



Explanation:

It is never a good idea to hardcode a password. Not only does hardcoding a password allow all of the project's developers to view the password, it also makes fixing the problem extremely difficult. Once the code is in production, the password cannot be changed without patching the software. If the account protected by the password is compromised, the owners of the system will be forced to choose between security and availability.

Example 1: The following code uses a hardcoded password to connect to a database:

```
...
DriverManager.getConnection(url, "scott", "tiger");
...
```

This code will run successfully, but anyone who has access to it will have access to the password. Once the program has shipped, there is no going back from the database user "scott" with a password of "tiger" unless the program is patched. A devious employee with access to this information can use it to break into the system. Even worse, if attackers have access to the bytecode for the application they can use the javap -c command to access the disassembled code, which will contain the values of the passwords used. The result of this operation might look something like the following for the example above:

```
javap -c ConnMngr.class
22: ldc   #36; //String jdbc:mysql://ixne.com/rxsql
24: ldc   #38; //String scott
26: ldc   #17; //String tiger
```

In the mobile world, password management is even trickier, considering a much higher chance of device loss.

Example 2: The code below uses hardcoded username and password to setup authentication for viewing protected pages with Android's WebView.

```
...
webview.setWebViewClient(new WebViewClient() {
public void onReceivedHttpAuthRequest(WebView view,
HttpAuthHandler handler, String host, String realm) {
handler.proceed("guest", "allow");
}
});
...
```

Similar to Example 1, this code will run successfully, but anyone who has access to it will have access to the password.

Recommendations:

Passwords should never be hardcoded and should generally be obfuscated and managed in an external source. Storing passwords in plaintext anywhere on the system allows anyone with sufficient permissions to read and potentially misuse the password. At the very least, passwords should be hashed before being stored.

Some third-party products claim the ability to manage passwords in a more secure way. For example, WebSphere Application Server 4.x uses a simple XOR encryption algorithm for obfuscating values, but be skeptical about such facilities. WebSphere and other application servers offer outdated and relatively weak encryption mechanisms that are insufficient for security-sensitive environments. For a secure generic solution, the best option today appears to be a proprietary mechanism that you create.

For Android, as well as any other platform that uses SQLite database, a good option is SQLCipher -- an extension to SQLite database that provides transparent 256-bit AES encryption of database files. Thus, credentials can be stored in an encrypted database.

Example 3: The code below demonstrates how to integrate SQLCipher into an Android application after downloading the necessary binaries, and store credentials into the database file.

```
import net.sqlcipher.database.SQLiteDatabase;
...
SQLiteDatabase.loadLibs(this);
File dbFile = getDatabasePath("credentials.db");
dbFile.mkdirs();
dbFile.delete();
SQLiteDatabase db = SQLiteDatabase.openOrCreateDatabase(dbFile, "credentials", null);
db.execSQL("create table credentials(u, p)");
db.execSQL("insert into credentials(u, p) values(?, ?)", new Object[]{username, password});
...
```

Note that references to android.database.sqlite.SQLiteDatabase are substituted with those of net.sqlcipher.database.SQLiteDatabase.

To enable encryption on the WebView store, WebKit has to be re-compiled with the sqlcipher.so library.

Tips:

1. The Fortify Java Annotations FortifyPassword and FortifyNotPassword can be used to indicate which fields and variables represent passwords.

2. When identifying null, empty, or hardcoded passwords, default rules only consider fields and variables that contain the word password. However, the HPE Security Fortify Custom Rules Editor provides the Password Management wizard that makes it easy to create rules for detecting password management issues on custom-named fields and variables.

Util.java, line 144 (Password Management: Hardcoded Password)

Fortify Priority:	High	**Folder**	High
Kingdom:	Security Features		
Abstract:	Hardcoded passwords may compromise system security in a way that cannot be easily remedied.		
Sink:	Util.java:144 FunctionCall: equalsIgnoreCase()		

```
142        if (password_history != null && !password_history.
143          equalsIgnoreCase("") && !password_history.
144          equalsIgnoreCase("null")) {
145
146         removeOldestPasswordIfNumberOfPasswordsGreaterThanLimit(password_history);
```

Detailed Project Summary

Files Scanned

Code base location: C:/AmersFiles/Gitworkspace/epds-auth

Files Scanned:

.settings/org.eclipse.wst.common.project.facet.core.prefs.xml xml 171 bytes May 9, 2016 6:30:22 PM

.settings/org.eclipse.wst.common.project.facet.core.xml xml 395 bytes May 9, 2016 6:30:22 PM

pom.xml xml 12.5 KB Jul 1, 2016 11:25:42 AM

src/main/java/gov/gao/epds/auth/config/AppConfig.java java 12 Lines 1.6 KB Jun 16, 2016 3:52:42 PM

src/main/java/gov/gao/epds/auth/config/MyApplicationConfiguration.java java 4 Lines 796 bytes May 18, 2016 4:14:38 PM

src/main/java/gov/gao/epds/auth/dao/Account_status_dao.java java 21 Lines 1.7 KB Dec 29, 2015 8:53:59 AM

src/main/java/gov/gao/epds/auth/dao/Auth_event_dao.java java 22 Lines 1.8 KB Dec 29, 2015 8:53:59 AM

src/main/java/gov/gao/epds/auth/dao/Login_attempt_dao.java java 56 Lines 5.1 KB Jun 16, 2016 4:52:31 PM

src/main/java/gov/gao/epds/auth/dao/Security_question_dao.java java 1 Lines 141 bytes Dec 29, 2015 8:53:59 AM

src/main/java/gov/gao/epds/auth/dao/User_info_dao.java java 56 Lines 4 KB Jun 16, 2016 4:34:47 PM

src/main/java/gov/gao/epds/auth/dao/User_role_dao.java java 1 Lines 133 bytes Dec 29, 2015 8:53:59 AM

src/main/java/gov/gao/epds/auth/dao/User_security_answer_dao.java java 39 Lines 3 KB Dec 30, 2015 8:50:42 AM

src/main/java/gov/gao/epds/auth/dto/AccountActivity.java java 8 Lines 1018 bytes Apr 21, 2016 10:36:49 AM

src/main/java/gov/gao/epds/auth/dto/AuthParam.java java 2 Lines 230 bytes Dec 29, 2015 8:53:59 AM

src/main/java/gov/gao/epds/auth/dto/Email.java java 7 Lines 933 bytes Apr 21, 2016 10:37:28 AM

src/main/java/gov/gao/epds/auth/dto/ForgotPasswordResponseDTO.java java 1 Lines 81 bytes Dec 29, 2015 8:53:59 AM

src/main/java/gov/gao/epds/auth/dto/Recaptcha.java java 5 Lines 721 bytes Jun 8, 2016 3:19:40 PM

src/main/java/gov/gao/epds/auth/dto/ServiceResponse.java java 14 Lines 1.1 KB Dec 29, 2015 8:53:59 AM

src/main/java/gov/gao/epds/auth/dto/User_info_dto.java java 91 Lines 8.1 KB May 15, 2016 11:45:28 AM

src/main/java/gov/gao/epds/auth/dto/User_info_epds.java java 55 Lines 4.6 KB Jan 19, 2016 9:53:18 AM

src/main/java/gov/gao/epds/auth/dto/User_session.java java 5 Lines 373 bytes Dec 29, 2015 8:53:59 AM

src/main/java/gov/gao/epds/auth/dto/ValidateToken.java java 7 Lines 1 KB Jul 15, 2016 10:56:27 AM

src/main/java/gov/gao/epds/auth/listeners/LoggerStartupListener.java java 10 Lines 1.3 KB Jun 7, 2016 11:03:18 AM

src/main/java/gov/gao/epds/auth/persistence/DataAccess.java java 180 Lines 12.2 KB Dec 29, 2015 8:53:59 AM

src/main/java/gov/gao/epds/auth/persistence/entity/Account_status.java java 7 Lines 823 bytes Dec 29, 2015 8:53:59 AM

src/main/java/gov/gao/epds/auth/persistence/entity/Auth_event.java java 13 Lines 1.4 KB Dec 29, 2015 8:53:59 AM

src/main/java/gov/gao/epds/auth/persistence/entity/CustomTrackingRevisionEntity.java java 10 Lines 1.9 KB Jun 6, 2016 9:50:21 AM

src/main/java/gov/gao/epds/auth/persistence/entity/Login_attempt.java java 15 Lines 1.7 KB Dec 29, 2015 8:53:59 AM

src/main/java/gov/gao/epds/auth/persistence/entity/Security_question.java java 5 Lines 695 bytes Dec 29, 2015 8:53:59 AM

src/main/java/gov/gao/epds/auth/persistence/entity/User_event.java java 5 Lines 674 bytes Dec 29, 2015 8:53:59 AM

src/main/java/gov/gao/epds/auth/persistence/entity/User_event_log.java java 9 Lines 1.2 KB Dec 29, 2015 8:53:59 AM

src/main/java/gov/gao/epds/auth/persistence/entity/User_info.java java 44 Lines 4.3 KB Jun 9, 2016 3:13:46 PM

src/main/java/gov/gao/epds/auth/persistence/entity/User_role.java java 7 Lines 746 bytes Dec 29, 2015 8:53:59 AM

src/main/java/gov/gao/epds/auth/persistence/entity/User_security_answer.java java 11 Lines 1.5 KB Jun 1, 2016 1:59:06 PM

src/main/java/gov/gao/epds/auth/persistence/entity/listener/CustomEntityTrackingRevisionListener.java java 10 Lines 2.2 KB Jun 16, 2016 12:45:09 AM

src/main/java/gov/gao/epds/auth/rest/AuthenticationService.java java 5 Lines 630 bytes May 18, 2016 1:17:56 PM

src/main/java/gov/gao/epds/auth/scheduler/AccountActivityScheduler.java java 23 Lines 4 KB Jun 17, 2016 8:54:32 AM

src/main/java/gov/gao/epds/auth/service/AccountUnlockService.java java 48 Lines 4.3 KB Jan 5, 2016 8:52:28 AM

src/main/java/gov/gao/epds/auth/service/AuthenticationService.java java 103 Lines 15.6 KB Jul 15, 2016 11:37:38 AM

src/main/java/gov/gao/epds/auth/service/EmailService.java java 129 Lines 9.8 KB Jul 13, 2016 4:46:59 AM

src/main/java/gov/gao/epds/auth/service/LoginService.java java 92 Lines 9.8 KB Jul 14, 2016 8:50:33 AM

src/main/java/gov/gao/epds/auth/service/TokenService.java java 59 Lines 4.5 KB May 6, 2016 12:33:44 PM

src/main/java/gov/gao/epds/auth/service/UserService.java java 227 Lines 17.3 KB Jun 13, 2016 9:02:20 AM

src/main/java/gov/gao/epds/auth/service/recaptcha/RecaptchaService.java java 149 bytes Jun 8, 2016 3:05:21 PM

src/main/java/gov/gao/epds/auth/service/recaptcha/RecaptchaServiceException.java java 2 Lines 291 bytes Jun 8, 2016 3:05:21 PM
src/main/java/gov/gao/epds/auth/service/recaptcha/RecaptchaServiceImpl.java java 20 Lines 2.8 KB Jun 14, 2016 3:46:42 AM
src/main/java/gov/gao/epds/auth/service/recaptcha/RestTemplateConfig.java java 6 Lines 1.2 KB Jul 1, 2016 11:10:19 AM
src/main/java/gov/gao/epds/auth/utils/AccountLockUtil.java java 29 Lines 2.7 KB Jan 11, 2016 12:15:53 PM
src/main/java/gov/gao/epds/auth/utils/AuthParam.java java 14 Lines 2 KB Mar 29, 2016 8:24:14 AM
src/main/java/gov/gao/epds/auth/utils/CustomerService.java java 5 Lines 577 bytes Dec 29, 2015 8:53:59 AM
src/main/java/gov/gao/epds/auth/utils/DateUtil.java java 12 Lines 1.7 KB Jun 15, 2016 9:30:01 AM
src/main/java/gov/gao/epds/auth/utils/GlobalParams.java java 15 Lines 1.6 KB Apr 22, 2016 9:03:40 AM
src/main/java/gov/gao/epds/auth/utils/LoginUtil.java java 6 Lines 536 bytes May 19, 2016 8:15:38 AM
src/main/java/gov/gao/epds/auth/utils/PasswordUtil.java java 82 Lines 7.7 KB Jun 16, 2016 5:13:21 PM
src/main/java/gov/gao/epds/auth/utils/PolicyParam.java java 18 Lines 2.2 KB Apr 22, 2016 9:14:18 AM
src/main/java/gov/gao/epds/auth/utils/PropertyFileEncrypter.java java 16 Lines 1.5 KB Jun 16, 2016 12:43:49 AM
src/main/java/gov/gao/epds/auth/utils/PwdValidator.java java 59 Lines 6.5 KB Jun 14, 2016 10:48:02 AM
src/main/java/gov/gao/epds/auth/utils/SpringApplicationContext.java java 4 Lines 720 bytes Dec 29, 2015 8:53:59 AM
src/main/java/gov/gao/epds/auth/utils/Util.java java 151 Lines 12.5 KB Jul 13, 2016 3:31:25 AM
src/main/java/gov/gao/epds/passwordutils/PasswordStorage.java java 68 Lines 6.5 KB May 13, 2016 4:33:55 PM
src/main/java/gov/gao/epds/passwordutils/Test.java java 75 Lines 4.9 KB May 18, 2016 3:16:55 PM
src/main/java/gov/gao/epds/persistence/DataAccess.java java 176 Lines 12 KB Jun 21, 2016 11:34:41 AM
src/main/java/gov/gao/epds/tokenutils/KeyStoreExample.java java 2.9 KB Jul 11, 2016 5:05:30 PM
src/main/java/gov/gao/epds/tokenutils/RemoveUnlimitedJCERestriction.java java 25 Lines 3.4 KB Jun 16, 2016 8:40:58 AM
src/main/java/gov/gao/epds/tokenutils/TokenTester.java java 11 Lines 1.6 KB May 9, 2016 5:48:55 PM
src/main/java/gov/gao/epds/tokenutils/TokenUtils.java java 143 Lines 10.4 KB Jul 7, 2016 1:03:10 PM
src/main/resources/accountActivity.tpl.html html 637 bytes May 17, 2016 1:04:26 PM
src/main/resources/emailTemplates/accountActivity.tpl.html html 637 bytes Apr 21, 2016 11:15:44 AM
src/main/resources/emailTemplates/temPwd.tpl.html html 1.9 KB Mar 24, 2016 3:53:20 PM
src/main/resources/epds.local.properties java_properties 621 bytes Jun 14, 2016 1:33:39 PM
src/main/resources/epds.oireasd0108.properties java_properties 489 bytes Jun 14, 2016 1:33:50 PM
src/main/resources/epds.oireasd0110.properties java_properties 491 bytes Jun 14, 2016 1:33:57 PM
src/main/resources/keystore.properties java_properties 363 bytes Jun 14, 2016 2:43:13 AM
src/main/resources/log4j.properties java_properties 872 bytes Jun 15, 2016 11:28:43 AM
src/main/resources/logback_bakup.xml xml 2.7 KB Jun 7, 2016 11:04:22 AM
src/main/resources/policy.param.properties java_properties 543 bytes May 15, 2016 11:42:06 AM
src/main/resources/temPwd.tpl.html html 1.9 KB Mar 24, 2016 3:53:20 PM
src/main/webapp/WEB-INF/spring/root-context.xml xml 380 bytes Dec 29, 2015 8:54:00 AM
src/main/webapp/WEB-INF/spring/spring-context.xml xml 5.5 KB Jun 14, 2016 2:56:10 PM
src/main/webapp/WEB-INF/web.xml xml 2.3 KB Dec 29, 2015 8:53:59 AM
src/main/webapp/hello.html html 136 bytes Dec 29, 2015 8:54:00 AM
src/test/java/gov/gao/epds/auth/test/JavaCodeTester.java java 14 Lines 1.2 KB Dec 29, 2015 8:53:59 AM
src/test/java/gov/gao/epds/auth/test/MethodTester.java java 6 Lines 567 bytes Dec 29, 2015 8:53:59 AM
src/test/java/gov/gao/epds/auth/test/TokenTester.java java 24 Lines 1.3 KB Dec 29, 2015 8:53:59 AM
target/classes/accountActivity.tpl.html html 637 bytes Jul 12, 2016 10:18:26 AM
target/classes/emailTemplates/accountActivity.tpl.html html 637 bytes Jul 12, 2016 10:18:26 AM
target/classes/emailTemplates/temPwd.tpl.html html 1.9 KB Jul 12, 2016 10:18:26 AM
target/classes/epds.local.properties java_properties 621 bytes Jul 12, 2016 10:18:26 AM
target/classes/epds.oireasd0108.properties java_properties 489 bytes Jul 12, 2016 10:18:26 AM
target/classes/epds.oireasd0110.properties java_properties 491 bytes Jul 12, 2016 10:18:26 AM
target/classes/keystore.properties java_properties 363 bytes Jul 12, 2016 10:18:26 AM
target/classes/log4j.properties java_properties 872 bytes Jul 12, 2016 10:18:26 AM
target/classes/logback_bakup.xml xml 2.7 KB Jul 12, 2016 10:18:26 AM
target/classes/policy.param.properties java_properties 543 bytes Jul 12, 2016 10:18:26 AM
target/classes/temPwd.tpl.html html 1.9 KB Jul 12, 2016 10:18:26 AM

target/m2e-wtp/web-resources/META-INF/maven/EPDS-AUTH/epds-auth/pom.properties java_properties 230 bytes Jul 19, 2016 4:53:04 PM
target/m2e-wtp/web-resources/META-INF/maven/EPDS-AUTH/epds-auth/pom.xml xml 12.5 KB Jul 19, 2016 4:53:04 PM
target/maven-archiver/pom.properties java_properties 117 bytes Jun 8, 2016 3:31:12 PM

Reference Elements

Classpath:

C:\Users\mhussaini\.m2\repository\antlr\antlr\2.7.7\antlr-2.7.7.jar
C:\Users\mhussaini\.m2\repository\aopalliance\aopalliance\1.0\aopalliance-1.0.jar
C:\Users\mhussaini\.m2\repository\ch\qos\logback\logback-classic\1.1.3\logback-classic-1.1.3.jar
C:\Users\mhussaini\.m2\repository\ch\qos\logback\logback-core\1.1.3\logback-core-1.1.3.jar
C:\Users\mhussaini\.m2\repository\com\fasterxml\jackson\core\jackson-annotations\2.7.0\jackson-annotations-2.7.0.jar
C:\Users\mhussaini\.m2\repository\com\fasterxml\jackson\core\jackson-core\2.7.4\jackson-core-2.7.4.jar
C:\Users\mhussaini\.m2\repository\com\fasterxml\jackson\core\jackson-databind\2.7.4\jackson-databind-2.7.4.jar
C:\Users\mhussaini\.m2\repository\com\google\code\gson\gson\2.3.1\gson-2.3.1.jar
C:\Users\mhussaini\.m2\repository\com\itextpdf\itextpdf\5.4.4\itextpdf-5.4.4.jar
C:\Users\mhussaini\.m2\repository\com\itextpdf\tool\xmlworker\5.4.4\xmlworker-5.4.4.jar
C:\Users\mhussaini\.m2\repository\com\jcraft\jsch\0.1.52\jsch-0.1.52.jar
C:\Users\mhussaini\.m2\repository\com\nimbusds\nimbus-jose-jwt\4.7\nimbus-jose-jwt-4.7.jar
C:\Users\mhussaini\.m2\repository\com\sun\istack\istack-commons-runtime\2.16\istack-commons-runtime-2.16.jar
C:\Users\mhussaini\.m2\repository\com\sun\xml\bind\jaxb-core\2.2.7\jaxb-core-2.2.7.jar
C:\Users\mhussaini\.m2\repository\com\sun\xml\bind\jaxb-impl\2.2.7\jaxb-impl-2.2.7.jar
C:\Users\mhussaini\.m2\repository\com\sun\xml\fastinfoset\FastInfoset\1.2.12\FastInfoset-1.2.12.jar
C:\Users\mhussaini\.m2\repository\commons-cli\commons-cli\1.2\commons-cli-1.2.jar
C:\Users\mhussaini\.m2\repository\commons-codec\commons-codec\1.9\commons-codec-1.9.jar
C:\Users\mhussaini\.m2\repository\commons-fileupload\commons-fileupload\1.2.2\commons-fileupload-1.2.2.jar
C:\Users\mhussaini\.m2\repository\commons-io\commons-io\2.4\commons-io-2.4.jar
C:\Users\mhussaini\.m2\repository\commons-logging\commons-logging\1.1.3\commons-logging-1.1.3.jar
C:\Users\mhussaini\.m2\repository\dom4j\dom4j\1.6.1\dom4j-1.6.1.jar
C:\Users\mhussaini\.m2\repository\edu\vt\middleware\vt-crypt\2.1.4\vt-crypt-2.1.4.jar
C:\Users\mhussaini\.m2\repository\edu\vt\middleware\vt-dictionary\3.0\vt-dictionary-3.0.jar
C:\Users\mhussaini\.m2\repository\edu\vt\middleware\vt-password\3.1.2\vt-password-3.1.2.jar
C:\Users\mhussaini\.m2\repository\javax\activation\activation\1.1.1\activation-1.1.1.jar
C:\Users\mhussaini\.m2\repository\javax\inject\javax.inject\1\javax.inject-1.jar
C:\Users\mhussaini\.m2\repository\javax\mail\mail\1.4\mail-1.4.jar
C:\Users\mhussaini\.m2\repository\javax\servlet\jsp\jsp-api\2.1\jsp-api-2.1.jar
C:\Users\mhussaini\.m2\repository\javax\servlet\jstl\1.2\jstl-1.2.jar
C:\Users\mhussaini\.m2\repository\javax\servlet\servlet-api\2.5\servlet-api-2.5.jar
C:\Users\mhussaini\.m2\repository\javax\xml\bind\jaxb-api\2.2.7\jaxb-api-2.2.7.jar
C:\Users\mhussaini\.m2\repository\javax\xml\bind\jsr173_api\1.0\jsr173_api-1.0.jar
C:\Users\mhussaini\.m2\repository\joda-time\joda-time\2.9.3\joda-time-2.9.3.jar
C:\Users\mhussaini\.m2\repository\junit\junit\4.7\junit-4.7.jar
C:\Users\mhussaini\.m2\repository\log4j\log4j\1.2.17\log4j-1.2.17.jar
C:\Users\mhussaini\.m2\repository\net\jcip\jcip-annotations\1.0\jcip-annotations-1.0.jar
C:\Users\mhussaini\.m2\repository\net\minidev\json-smart\1.3.1\json-smart-1.3.1.jar
C:\Users\mhussaini\.m2\repository\org\apache\commons\commons-email\1.2\commons-email-1.2.jar
C:\Users\mhussaini\.m2\repository\org\apache\httpcomponents\httpclient\4.5.2\httpclient-4.5.2.jar
C:\Users\mhussaini\.m2\repository\org\apache\httpcomponents\httpcore\4.4.1\httpcore-4.4.1.jar
C:\Users\mhussaini\.m2\repository\org\apache\poi\poi-ooxml-schemas\3.9\poi-ooxml-schemas-3.9.jar

C:\Users\mhussaini\.m2\repository\org\apache\poi\poi-ooxml\3.9\poi-ooxml-3.9.jar
C:\Users\mhussaini\.m2\repository\org\apache\poi\poi\3.9\poi-3.9.jar
C:\Users\mhussaini\.m2\repository\org\apache\tomcat\tomcat-jdbc\7.0.47\tomcat-jdbc-7.0.47.jar
C:\Users\mhussaini\.m2\repository\org\apache\tomcat\tomcat-juli\7.0.47\tomcat-juli-7.0.47.jar
C:\Users\mhussaini\.m2\repository\org\apache\xmlbeans\xmlbeans\2.3.0\xmlbeans-2.3.0.jar
C:\Users\mhussaini\.m2\repository\org\aspectj\aspectjrt\1.8.1\aspectjrt-1.8.1.jar
C:\Users\mhussaini\.m2\repository\org\bouncycastle\bcprov-ext-jdk15on\1.53\bcprov-ext-jdk15on-1.53.jar
C:\Users\mhussaini\.m2\repository\org\bouncycastle\bcprov-jdk15\1.45\bcprov-jdk15-1.45.jar
C:\Users\mhussaini\.m2\repository\org\bouncycastle\bcprov-jdk15on\1.53\bcprov-jdk15on-1.53.jar
C:\Users\mhussaini\.m2\repository\org\codehaus\jackson\jackson-core-asl\1.9.12\jackson-core-asl-1.9.12.jar
C:\Users\mhussaini\.m2\repository\org\codehaus\jackson\jackson-jaxrs\1.9.12\jackson-jaxrs-1.9.12.jar
C:\Users\mhussaini\.m2\repository\org\codehaus\jackson\jackson-mapper-asl\1.9.12\jackson-mapper-asl-1.9.12.jar
C:\Users\mhussaini\.m2\repository\org\codehaus\jackson\jackson-xc\1.9.12\jackson-xc-1.9.12.jar
C:\Users\mhussaini\.m2\repository\org\codehaus\jettison\jettison\1.3.2\jettison-1.3.2.jar
C:\Users\mhussaini\.m2\repository\org\hibernate\common\hibernate-commons-annotations\4.0.2.Final\hibernate-commons-annotations-4.0.2.Final.jar
C:\Users\mhussaini\.m2\repository\org\hibernate\hibernate-core\4.2.7.Final\hibernate-core-4.2.7.Final.jar
C:\Users\mhussaini\.m2\repository\org\hibernate\hibernate-entitymanager\4.1.7.Final\hibernate-entitymanager-4.1.7.Final.jar
C:\Users\mhussaini\.m2\repository\org\hibernate\hibernate-envers\4.1.7.Final\hibernate-envers-4.1.7.Final.jar
C:\Users\mhussaini\.m2\repository\org\hibernate\javax\persistence\hibernate-jpa-2.0-api\1.0.1.Final\hibernate-jpa-2.0-api-1.0.1.Final.jar
C:\Users\mhussaini\.m2\repository\org\jasypt\jasypt\1.9.2\jasypt-1.9.2.jar
C:\Users\mhussaini\.m2\repository\org\javassist\javassist\3.18.1-GA\javassist-3.18.1-GA.jar
C:\Users\mhussaini\.m2\repository\org\jboss\logging\jboss-logging\3.1.0.GA\jboss-logging-3.1.0.GA.jar
C:\Users\mhussaini\.m2\repository\org\jboss\resteasy\resteasy-client\3.0.13.Final\resteasy-client-3.0.13.Final.jar
C:\Users\mhussaini\.m2\repository\org\jboss\resteasy\resteasy-jackson-provider\3.0.13.Final\resteasy-jackson-provider-3.0.13.Final.jar
C:\Users\mhussaini\.m2\repository\org\jboss\resteasy\resteasy-jaxb-provider\3.0.13.Final\resteasy-jaxb-provider-3.0.13.Final.jar
C:\Users\mhussaini\.m2\repository\org\jboss\resteasy\resteasy-jaxrs\3.0.13.Final\resteasy-jaxrs-3.0.13.Final.jar
C:\Users\mhussaini\.m2\repository\org\jboss\resteasy\resteasy-jettison-provider\3.0.13.Final\resteasy-jettison-provider-3.0.13.Final.jar
C:\Users\mhussaini\.m2\repository\org\jboss\resteasy\resteasy-spring\3.0.13.Final\resteasy-spring-3.0.13.Final.jar
C:\Users\mhussaini\.m2\repository\org\jboss\spec\javax\annotation\jboss-annotations-api_1.2_spec\1.0.0.Final\jboss-annotations-api_1.2_spec-1.0.0.Final.jar
C:\Users\mhussaini\.m2\repository\org\jboss\spec\javax\transaction\jboss-transaction-api_1.1_spec\1.0.1.Final\jboss-transaction-api_1.1_spec-1.0.1.Final.jar
C:\Users\mhussaini\.m2\repository\org\jboss\spec\javax\ws\rs\jboss-jaxrs-api_2.0_spec\1.0.0.Final\jboss-jaxrs-api_2.0_spec-1.0.0.Final.jar
C:\Users\mhussaini\.m2\repository\org\slf4j\jcl-over-slf4j\1.7.12\jcl-over-slf4j-1.7.12.jar
C:\Users\mhussaini\.m2\repository\org\slf4j\slf4j-api\1.7.12\slf4j-api-1.7.12.jar
C:\Users\mhussaini\.m2\repository\org\slf4j\slf4j-log4j12\1.7.12\slf4j-log4j12-1.7.12.jar
C:\Users\mhussaini\.m2\repository\org\springframework\security\spring-security-config\4.0.1.RELEASE\spring-security-config-4.0.1.RELEASE.jar
C:\Users\mhussaini\.m2\repository\org\springframework\security\spring-security-core\4.0.1.RELEASE\spring-security-core-4.0.1.RELEASE.jar
C:\Users\mhussaini\.m2\repository\org\springframework\security\spring-security-web\4.0.1.RELEASE\spring-security-web-4.0.1.RELEASE.jar
C:\Users\mhussaini\.m2\repository\org\springframework\spring-aop\4.1.6.RELEASE\spring-aop-4.1.6.RELEASE.jar
C:\Users\mhussaini\.m2\repository\org\springframework\spring-beans\4.1.6.RELEASE\spring-beans-4.1.6.RELEASE.jar
C:\Users\mhussaini\.m2\repository\org\springframework\spring-context-support\4.0.1.RELEASE\spring-context-support-4.0.1.RELEASE.jar

C:\Users\mhussaini\.m2\repository\org\springframework\spring-context\4.1.6.RELEASE\spring-context-4.1.6.RELEASE.jar
C:\Users\mhussaini\.m2\repository\org\springframework\spring-core\4.1.6.RELEASE\spring-core-4.1.6.RELEASE.jar
C:\Users\mhussaini\.m2\repository\org\springframework\spring-expression\4.1.6.RELEASE\spring-expression-4.1.6.RELEASE.jar
C:\Users\mhussaini\.m2\repository\org\springframework\spring-jdbc\4.1.6.RELEASE\spring-jdbc-4.1.6.RELEASE.jar
C:\Users\mhussaini\.m2\repository\org\springframework\spring-orm\4.1.6.RELEASE\spring-orm-4.1.6.RELEASE.jar
C:\Users\mhussaini\.m2\repository\org\springframework\spring-tx\4.1.6.RELEASE\spring-tx-4.1.6.RELEASE.jar
C:\Users\mhussaini\.m2\repository\org\springframework\spring-web\4.1.6.RELEASE\spring-web-4.1.6.RELEASE.jar
C:\Users\mhussaini\.m2\repository\org\springframework\spring-webmvc\4.1.6.RELEASE\spring-webmvc-4.1.6.RELEASE.jar
C:\Users\mhussaini\.m2\repository\stax\stax-api\1.0.1\stax-api-1.0.1.jar
C:\Users\mhussaini\Downloads\ojdbc7.jar
C:\Users\mhussaini\jboss-eap\modules\system\layers\base\javax\activation\api\main\activation-1.1.1-redhat-2.jar
C:\Users\mhussaini\jboss-eap\modules\system\layers\base\javax\annotation\api\main\jboss-annotations-api_1.1_spec-1.0.1.Final-redhat-2.jar
C:\Users\mhussaini\jboss-eap\modules\system\layers\base\javax\ejb\api\main\jboss-ejb-api_3.1_spec-1.0.2.Final-redhat-2.jar
C:\Users\mhussaini\jboss-eap\modules\system\layers\base\javax\el\api\main\jboss-el-api_2.2_spec-1.0.4.Final-redhat-1.jar
C:\Users\mhussaini\jboss-eap\modules\system\layers\base\javax\enterprise\api\main\cdi-api-1.0-SP4-redhat-4.jar
C:\Users\mhussaini\jboss-eap\modules\system\layers\base\javax\enterprise\deploy\api\main\jboss-jad-api_1.2_spec-1.0.1.Final-redhat-2.jar
C:\Users\mhussaini\jboss-eap\modules\system\layers\base\javax\faces\api\main\jboss-jsf-api_2.1_spec-2.1.28.Final-redhat-1.jar
C:\Users\mhussaini\jboss-eap\modules\system\layers\base\javax\inject\api\main\javax.inject-1.redhat-4.jar
C:\Users\mhussaini\jboss-eap\modules\system\layers\base\javax\interceptor\api\main\jboss-interceptors-api_1.1_spec-1.0.1.Final-redhat-2.jar
C:\Users\mhussaini\jboss-eap\modules\system\layers\base\javax\jms\api\main\jboss-jms-api_1.1_spec-1.0.1.Final-redhat-2.jar
C:\Users\mhussaini\jboss-eap\modules\system\layers\base\javax\jws\api\main\jsr181-api-1.0-MR1-redhat-6.jar
C:\Users\mhussaini\jboss-eap\modules\system\layers\base\javax\mail\api\main\mail-1.4.5-redhat-1.jar
C:\Users\mhussaini\jboss-eap\modules\system\layers\base\javax\management\j2ee\api\main\jboss-j2eemgmt-api_1.1_spec-1.0.1.Final-redhat-2.jar
C:\Users\mhussaini\jboss-eap\modules\system\layers\base\javax\persistence\api\main\hibernate-jpa-2.0-api-1.0.1.Final-redhat-2.jar
C:\Users\mhussaini\jboss-eap\modules\system\layers\base\javax\resource\api\main\jboss-connector-api_1.6_spec-1.0.1.Final-redhat-2.jar
C:\Users\mhussaini\jboss-eap\modules\system\layers\base\javax\rmi\api\main\jboss-rmi-api_1.0_spec-1.0.4.Final-redhat-2.jar
C:\Users\mhussaini\jboss-eap\modules\system\layers\base\javax\security\auth\message\api\main\jboss-jaspi-api_1.0_spec-1.0.1.Final-redhat-2.jar
C:\Users\mhussaini\jboss-eap\modules\system\layers\base\javax\security\jacc\api\main\jboss-jacc-api_1.4_spec-1.0.3.Final-redhat-1.jar
C:\Users\mhussaini\jboss-eap\modules\system\layers\base\javax\servlet\api\main\jboss-servlet-api_3.0_spec-1.0.2.Final-redhat-1.jar
C:\Users\mhussaini\jboss-eap\modules\system\layers\base\javax\servlet\jsp\api\main\jboss-jsp-api_2.2_spec-1.0.1.Final-redhat-2.jar
C:\Users\mhussaini\jboss-eap\modules\system\layers\base\javax\servlet\jstl\api\main\jboss-jstl-api_1.2_spec-1.0.6.Final-redhat-1.jar
C:\Users\mhussaini\jboss-eap\modules\system\layers\base\javax\transaction\api\main\jboss-transaction-api_1.1_spec-1.0.1.Final-redhat-2.jar
C:\Users\mhussaini\jboss-eap\modules\system\layers\base\javax\validation\api\main\validation-api-1.0.0.GA-redhat-2.jar
C:\Users\mhussaini\jboss-eap\modules\system\layers\base\javax\ws\rs\api\main\jboss-jaxrs-api_1.1_spec-1.0.1.Final-redhat-2.jar
C:\Users\mhussaini\jboss-eap\modules\system\layers\base\javax\wsdl4j\api\main\wsdl4j-1.6.3.redhat-1.jar
C:\Users\mhussaini\jboss-eap\modules\system\layers\base\javax\xml\bind\api\main\jboss-jaxb-api_2.2_spec-1.0.4.Final-redhat-2.jar
C:\Users\mhussaini\jboss-eap\modules\system\layers\base\javax\xml\registry\api\main\jboss-jaxr-api_1.0_spec-1.0.2.Final-

redhat-2.jar
C:\Users\mhussaini\jboss-eap\modules\system\layers\base\javax\xml\rpc\api\main\jboss-jaxrpc-api_1.1_spec-1.0.1.Final-redhat-3.jar
C:\Users\mhussaini\jboss-eap\modules\system\layers\base\javax\xml\soap\api\main\jboss-saaj-api_1.3_spec-1.0.3.Final-redhat-1.jar
C:\Users\mhussaini\jboss-eap\modules\system\layers\base\javax\xml\ws\api\main\jboss-jaxws-api_2.2_spec-2.0.2.Final-redhat-1.jar
C:\Users\mhussaini\jboss-eap\modules\system\layers\base\org\hibernate\validator\main\hibernate-validator-4.3.1.Final-redhat-1.jar
C:\Users\mhussaini\jboss-eap\modules\system\layers\base\org\jboss\as\controller-client\main\jboss-as-controller-client-7.4.0.Final-redhat-19.jar
C:\Users\mhussaini\jboss-eap\modules\system\layers\base\org\jboss\dmr\main\jboss-dmr-1.2.0.Final-redhat-1.jar
C:\Users\mhussaini\jboss-eap\modules\system\layers\base\org\jboss\ejb3\main\jboss-ejb3-ext-api-2.1.0.redhat-1.jar
C:\Users\mhussaini\jboss-eap\modules\system\layers\base\org\jboss\logging\main\jboss-logging-3.1.4.GA-redhat-1.jar
C:\Users\mhussaini\jboss-eap\modules\system\layers\base\org\jboss\resteasy\resteasy-jaxb-provider\main\resteasy-jaxb-provider-2.3.8.Final-redhat-3.jar
C:\Users\mhussaini\jboss-eap\modules\system\layers\base\org\jboss\resteasy\resteasy-jaxrs\main\async-http-servlet-3.0-2.3.8.Final-redhat-3.jar
C:\Users\mhussaini\jboss-eap\modules\system\layers\base\org\jboss\resteasy\resteasy-jaxrs\main\resteasy-jaxrs-2.3.8.Final-redhat-3.jar
C:\Users\mhussaini\jboss-eap\modules\system\layers\base\org\jboss\resteasy\resteasy-multipart-provider\main\resteasy-multipart-provider-2.3.8.Final-redhat-3.jar
C:\Users\mhussaini\jboss-eap\modules\system\layers\base\org\picketbox\main\picketbox-4.0.19.SP8-redhat-1.jar
C:\Users\mhussaini\jboss-eap\modules\system\layers\base\org\picketbox\main\picketbox-commons-1.0.0.final-redhat-2.jar
C:\Users\mhussaini\jboss-eap\modules\system\layers\base\org\picketbox\main\picketbox-infinispan-4.0.19.SP8-redhat-1.jar

Libdirs:

No libdirs specified during translation

Rulepacks

Valid Rulepacks:

Name: HPE Security Fortify Secure Coding Rules, Core, ABAP
Version: 2016.1.0.0008
ID: 5A663288-B1F7-416A-AEED-E5F00DC3596F
SKU: RUL13095

Name: Fortify Secure Coding Rules, Core Preview, ABAP
Version: 2014.4.0.0008
ID: 5249BACE-3D49-4937-BFFF-48BA414E14DD
SKU: RUL13187

Name: HPE Security Fortify Secure Coding Rules, Core, ActionScript 3.0
Version: 2016.1.0.0008
ID: 92127AA2-E666-4F28-B1C1-C0F6A939A089
SKU: RUL13094

Name: HPE Security Fortify Secure Coding Rules, Core, Android

Version: 2016.1.0.0008
ID: FF9890E6-D119-4EE8-A591-83DCF4CA6952
SKU: RUL13093

Name: HPE Security Fortify Secure Coding Rules, Core, Annotations
Version: 2016.1.0.0008
ID: 14EE50EB-FA1C-4AE8-8B59-39F952E21E3B
SKU: RUL13078

Name: HPE Security Fortify Secure Coding Rules, Core, ColdFusion
Version: 2016.1.0.0008
ID: EEA7C678-058E-462A-8A59-AF925F7B7164
SKU: RUL13024

Name: HPE Security Fortify Secure Coding Rules, Core, COBOL
Version: 2016.1.0.0008
ID: 9EB21F2C-ED22-440B-82A3-E38DC2533F03
SKU: RUL13088

Name: HPE Security Fortify Secure Coding Rules, Core, C/C++
Version: 2016.1.0.0008
ID: 711E0652-7494-42BE-94B1-DB3799418C7E
SKU: RUL13001

Name: HPE Security Fortify Secure Coding Rules, Core, .NET
Version: 2016.1.0.0008
ID: D57210E5-E762-4112-97DD-019E61D32D0E
SKU: RUL13002

Name: HPE Security Fortify Secure Coding Rules, Core, Java
Version: 2016.1.0.0008
ID: 06A6CC97-8C3F-4E73-9093-3E74C64A2AAF
SKU: RUL13003

Name: HPE Security Fortify Secure Coding Rules, Core, JavaScript
Version: 2016.1.0.0008
ID: BD292C4E-4216-4DB8-96C7-9B607BFD9584
SKU: RUL13059

Name: HPE Security Fortify Secure Coding Rules, Core, Objective-C
Version: 2016.1.0.0008
ID: B18E58BA-8B2D-4FC5-83BF-378594CAD260
SKU: RUL13099

Name: HPE Security Fortify Secure Coding Rules, Core, PHP
Version: 2016.1.0.0008
ID: 343CBB32-087C-4A4E-8BD8-273B5F876069
SKU: RUL13058

Name: HPE Security Fortify Secure Coding Rules, Core, Python
Version: 2016.1.0.0008

ID: FD15CBE4-E059-4CBB-914E-546BDCEB422B
SKU: RUL13083

Name: HPE Security Fortify Secure Coding Rules, Core, Ruby
Version: 2016.1.0.0008
ID: CA8013D5-11DE-44EF-9563-182F9FCB87BC
SKU: RUL13135

Name: HPE Security Fortify Secure Coding Rules, Core, SQL
Version: 2016.1.0.0008
ID: 6494160B-E1DB-41F5-9840-2B1609EE7649
SKU: RUL13004

Name: HPE Security Fortify Secure Coding Rules, Core, Swift
Version: 2016.1.0.0008
ID: A977528A-B2C7-412D-9691-F1668E05154B
SKU: RUL13147

Name: HPE Security Fortify Secure Coding Rules, Core, Classic ASP, VBScript, and VB6
Version: 2016.1.0.0008
ID: 1D426B6F-8D33-4AD6-BBCE-237ABAFAB924
SKU: RUL13060

Name: HPE Security Fortify Secure Coding Rules, Extended, Configuration
Version: 2016.1.0.0008
ID: CD6959FC-0C37-45BE-9637-BAA43C3A4D56
SKU: RUL13005

Name: HPE Security Fortify Secure Coding Rules, Extended, Content
Version: 2016.1.0.0008
ID: 9C48678C-09B6-474D-B86D-97EE94D38F17
SKU: RUL13067

Name: HPE Security Fortify Secure Coding Rules, Extended, C/C++
Version: 2016.1.0.0008
ID: BD4641AD-A6FF-4401-A8F4-6873272F2748
SKU: RUL13006

Name: HPE Security Fortify Secure Coding Rules, Extended, .NET
Version: 2016.1.0.0008
ID: 557BCC56-CD42-43A7-B4FE-CDD00D58577E
SKU: RUL13027

Name: HPE Security Fortify Secure Coding Rules, Extended, Java
Version: 2016.1.0.0008
ID: AAAC0B10-79E7-4FE5-9921-F4903A79D317
SKU: RUL13007

Name: HPE Security Fortify Secure Coding Rules, Extended, JavaScript
Version: 2016.1.0.0008
ID: C4D1969E-B734-47D3-87D4-73962C1D32E2

SKU: RUL13141

Name: HPE Security Fortify Secure Coding Rules, Extended, JSP
Version: 2016.1.0.0008
ID: 00403342-15D0-48C9-8E67-4B1CFBDEFCD2
SKU: RUL13026

Name: HPE Security Fortify Secure Coding Rules, Extended, SQL
Version: 2016.1.0.0008
ID: 4BC5B2FA-C209-4DBC-9C3E-1D3EEFAF135A
SKU: RUL13025

External Metadata:

Name: CWE
ID: 3ADB9EE4-5761-4289-8BD3-CBFCC593EBBC

Name: FISMA
ID: B40F9EE0-3824-4879-B9FE-7A789C89307C

Name: NIST SP 800-53 Rev.4
ID: 1114583B-EA24-45BE-B7F8-B61201BACDD0

Name: OWASP Mobile 2014
ID: EEE3F9E7-28D6-4456-8761-3DA56C36F4EE

Name: OWASP Top 10 2004
ID: 771C470C-9274-4580-8556-C023E4D3ADB4

Name: OWASP Top 10 2007
ID: 1EB1EC0E-74E6-49A0-BCE5-E6603802987A

Name: OWASP Top 10 2010
ID: FDCECA5E-C2A8-4BE8-BB26-76A8ECD0ED59

Name: OWASP Top 10 2013
ID: 1A2B4C7E-93B0-4502-878A-9BE40D2A25C4

Name: PCI 1.1
ID: CBDB9D4D-FC20-4C04-AD58-575901CAB531

Name: PCI 1.2
ID: 57940BDB-99F0-48BF-BF2E-CFC42BA035E5

Name: PCI 2.0
ID: 8970556D-7F9F-4EA7-8033-9DF39D68FF3E

Name: PCI 3.0
ID: E2FB0D38-0192-4F03-8E01-FE2A12680CA3

Name: PCI 3.1

ID: AC0D18CF-C1DA-47CF-9F1A-E8EC0A4A717E

Name: SANS Top 25 2009
ID: 939EF193-507A-44E2-ABB7-C00B2168B6D8

Name: SANS Top 25 2010
ID: 72688795-4F7B-484C-88A6-D4757A6121CA

Name: SANS Top 25 2011
ID: 92EB4481-1FD9-4165-8E16-F2DE6CB0BD63

Name: STIG 3.1
ID: F2FA57EA-5AAA-4DDE-90A5-480BE65CE7E7

Name: STIG 3.10
ID: 788A87FE-C9F9-4533-9095-0379A9B35B12

Name: STIG 3.4
ID: 58E2C21D-C70F-4314-8994-B859E24CF855

Name: STIG 3.5
ID: DD18E81F-3507-41FA-9DFA-2A9A15B5479F

Name: STIG 3.6
ID: 000CA760-0FED-4374-8AA2-6FA3968A07B1

Name: STIG 3.7
ID: E69C07C0-81D8-4B04-9233-F3E74167C3D2

Name: STIG 3.9
ID: 1A9D736B-2D4A-49D1-88CA-DF464B40D732

Name: WASC 2.00
ID: 74f8081d-dd49-49da-880f-6830cebe9777

Name: WASC 24 + 2
ID: 9DC61E7F-1A48-4711-BBFD-E9DFF537871F

Properties

WinForms.CollectionMutationMonitor.Label=WinFormsDataSource
WinForms.ExtractEventHandlers=true
WinForms.TransformChangeNotificationPattern=true
WinForms.TransformDataBindings=true
WinForms.TransformMessageLoops=true
awt.toolkit=sun.awt.windows.WToolkit
com.fortify.AuthenticationKey=C:\Users\mhussaini\AppData\Local/Fortify/config/tools
com.fortify.Core=C:\Program Files\HP_Fortify\HP_Fortify_SCA_and_Apps_4.30\Core
com.fortify.InstallRoot=C:\Program Files\HP_Fortify\HP_Fortify_SCA_and_Apps_4.30
com.fortify.InstallationUserName=MHussaini

com.fortify.SCAExecutablePath=C:Program FilesHP_FortifyHP_Fortify_SCA_and_Apps_4.30binsourceanalyzer.exe
com.fortify.TotalPhysicalMemory=16971313152
com.fortify.VS.DefaultFramework.10.0=DotNetFrameworkv40
com.fortify.VS.DefaultFramework.11.0=DotNetFrameworkv45
com.fortify.VS.DefaultFramework.12.0=DotNetFrameworkv451
com.fortify.VS.DefaultFramework.14.0=DotNetFrameworkv451
com.fortify.VS.Frameworks.DotNetFrameworkv11.SDKRegistry="SOFTWARE\Microsoft\.NETFramework","sdkInstallRootv1.1","\bin"
com.fortify.VS.Frameworks.DotNetFrameworkv11.VSProjectVersionCode=1;
com.fortify.VS.Frameworks.DotNetFrameworkv20.SDKRegistry="SOFTWARE\Microsoft\.NETFramework","sdkInstallRootv2.0","\bin"
com.fortify.VS.Frameworks.DotNetFrameworkv20.VSProjectVersionCode=131072
com.fortify.VS.Frameworks.DotNetFrameworkv30.SDKRegistry="SOFTWARE\Microsoft\Microsoft SDKs\Windows\v6.0A","InstallationFolder"
com.fortify.VS.Frameworks.DotNetFrameworkv30.VSProjectVersionCode=196608
com.fortify.VS.Frameworks.DotNetFrameworkv35.SDKRegistry="SOFTWARE\Microsoft\Microsoft SDKs\Windows\v6.0A","InstallationFolder"
com.fortify.VS.Frameworks.DotNetFrameworkv35.VSProjectVersionCode=196613
com.fortify.VS.Frameworks.DotNetFrameworkv40.DotNetFolder="v4.0.30319"
com.fortify.VS.Frameworks.DotNetFrameworkv40.SDKRegistry="SOFTWARE\Microsoft\Microsoft SDKs\Windows\v7.0A\WinSDK-NetFx40Tools-x86","InstallationFolder"
com.fortify.VS.Frameworks.DotNetFrameworkv40.VSProjectVersionCode=262144
com.fortify.VS.Frameworks.DotNetFrameworkv45.DotNetFolder="v4.0.30319"
com.fortify.VS.Frameworks.DotNetFrameworkv45.SDKPaths="Microsoft SDKs\Windows\v8.0A\bin\NETFX 4.0 Tools\";"Microsoft SDKs\Windows\v8.0A\bin\";"Microsoft SDKs\Windows\v8.0\bin\NETFX 4.0 Tools\";"Microsoft SDKs\Windows\v8.0\bin\"
com.fortify.VS.Frameworks.DotNetFrameworkv45.SDKRegistry="SOFTWARE\Microsoft\Microsoft SDKs\Windows\v8.0A\WinSDK-NetFx40Tools-x86","InstallationFolder"
com.fortify.VS.Frameworks.DotNetFrameworkv45.VSProjectVersionCode=262149
com.fortify.VS.Frameworks.DotNetFrameworkv451.DotNetFolder="v4.0.30319"
com.fortify.VS.Frameworks.DotNetFrameworkv451.SDKPaths="Microsoft SDKs\Windows\v8.1A\bin\NETFX 4.5.1 Tools\";"Microsoft SDKs\Windows\v8.1A\bin\";"Microsoft SDKs\Windows\v8.1\bin\NETFX 4.5.1 Tools\";"Microsoft SDKs\Windows\v8.1\bin\"
com.fortify.VS.Frameworks.DotNetFrameworkv451.SDKRegistry="SOFTWARE\Microsoft\Microsoft SDKs\Windows\v8.1A\WinSDK-NetFx40Tools-x86","InstallationFolder"
com.fortify.VS.Frameworks.DotNetFrameworkv451.VSProjectVersionCode=451
com.fortify.VS.Frameworks.default.SDKRegistry="SOFTWARE\Microsoft\Microsoft SDKs\Windows\v8.0A\WinSDK-NetFx35Tools-x86","InstallationFolder";"SOFTWARE\Microsoft\Microsoft SDKs\Windows\v7.0A\WinSDK-NetFx35Tools-x86","InstallationFolder";"SOFTWARE\Microsoft\Microsoft SDKs\Windows\v6.1","InstallationFolder","\bin"
com.fortify.VS.Frameworks.default.VSProjectVersionCode=-1
com.fortify.VS.RequireASPPrecompilation=true
com.fortify.WorkingDirectory=C:\Users\mhussaini\AppData\Local/Fortify
com.fortify.locale=en
com.fortify.sca.AddImpliedMethods=true
com.fortify.sca.AntCompilerClass=com.fortify.dev.ant.SCACompiler
com.fortify.sca.BuildID=epds-auth
com.fortify.sca.BundleControlflowIssues=true
com.fortify.sca.BytecodePreview=true
com.fortify.sca.CollectPerformanceData=true
com.fortify.sca.CustomRulesDir=C:\Program Files\HP_Fortify\HP_Fortify_SCA_and_Apps_4.30\Core\config\customrules
com.fortify.sca.DaemonCompilers=com.fortify.sca.util.compilers.GppCompiler,com.fortify.sca.util.compilers.GccCompiler,com.f

ortify.sca.util.compilers.AppleGppCompiler,com.fortify.sca.util.compilers.AppleGccCompiler,com.fortify.sca.util.compilers.MicrosoftCompiler,com.fortify.sca.util.compilers.MicrosoftLinker,com.fortify.sca.util.compilers.LdCompiler,com.fortify.sca.util.compilers.ArUtil,com.fortify.sca.util.compilers.SunCCompiler,com.fortify.sca.util.compilers.SunCppCompiler,com.fortify.sca.util.compilers.IntelCompiler,com.fortify.sca.util.compilers.ExternalCppAdapter,com.fortify.sca.util.compilers.ClangCompiler
com.fortify.sca.DeadCodeFilter=true
com.fortify.sca.DeadCodeIgnoreTrivialPredicates=true
com.fortify.sca.DefaultAnalyzers=semantic:dataflow:controlflow:nullptr:configuration:content:structural:buffer
com.fortify.sca.DefaultFileTypes=java,rb,jsp,jspx,tag,tagx,tld,sql,cfm,php,phtml,ctp,pks,pkh,pkb,xml,config,settings,properties,dll,exe,inc,asp,vbscript,js,ini,bas,cls,vbs,frm,ctl,html,htm,xsd,wsdd,xmi,py,cfml,cfc,abap,xhtml,cpx,xcfg,jsff,as,mxml,cbl,cscfg,csdef,wadcfg,appxmanifest,wsdl,plist
com.fortify.sca.DefaultJarsDirs=default_jars
com.fortify.sca.DefaultRulesDir=C:\Program Files\HP_Fortify\HP_Fortify_SCA_and_Apps_4.30\Core\config\rules
com.fortify.sca.DisableDeadCodeElimination=false
com.fortify.sca.DisableFunctionPointers=false
com.fortify.sca.DisableGlobals=false
com.fortify.sca.DisableInferredConstants=false
com.fortify.sca.DisplayProgress=true
com.fortify.sca.EnableInterproceduralConstantResolution=true
com.fortify.sca.EnableNestedWrappers=true
com.fortify.sca.EnableStructuralMatchCache=true
com.fortify.sca.EnableWrapperDetection=true
com.fortify.sca.FVDLDisableDescriptions=false
com.fortify.sca.FVDLDisableProgramData=false
com.fortify.sca.FVDLDisableSnippets=false
com.fortify.sca.FVDLStylesheet=C:\Program Files\HP_Fortify\HP_Fortify_SCA_and_Apps_4.30\Core/resources/sca/fvdl2html.xsl
com.fortify.sca.IndirectCallGraphBuilders=WinFormsAdHocFunctionBuilder,VirtualCGBuilder,J2EEIndirectCGBuilder,JNICGBuilder,StoredProcedureResolver,JavaWSCGBuilder,StrutsCGBuilder,DotNetWSCGBuilder,SqlServerSPResolver,ASPCGBuilder,ScriptedCGBuilder,NewJspCustomTagCGBuilder,DotNetCABCGBuilder,StateInjectionCGBuilder,SqlServerSPResolver2,PHPLambdaResolver,JavaWebCGBuilder
com.fortify.sca.JVMArgs=-Djava.awt.headless=true -Dcom.sun.management.jmxremote=true -XX:SoftRefLRUPolicyMSPerMB=3000 -Xss16M -Xmx1800M -Xms300M -server
com.fortify.sca.JavaNewBeta=true
com.fortify.sca.JdkVersion=1.5
com.fortify.sca.LowSeverityCutoff=1.0
com.fortify.sca.MachineOutputMode=
com.fortify.sca.NoNestedOutTagOutput=org.apache.taglibs.standard.tag.rt.core.RemoveTag,org.apache.taglibs.standard.tag.rt.core.SetTag
com.fortify.sca.PID=3768
com.fortify.sca.Phase0HigherOrder.Languages=python,ruby
com.fortify.sca.Phase0HigherOrder.Level=1
com.fortify.sca.Phase0HigherOrder.Limiter.Values=16
com.fortify.sca.PidFile=C:\Users\MHUSSA~1\AppData\Local\Temp\1\PID205445936769652370.tmp
com.fortify.sca.PrintPerformanceDataAfterScan=false
com.fortify.sca.ProjectRoot=C:\Users\mhussaini\AppData\Local/Fortify
com.fortify.sca.ProjectRoot=C:\Users\mhussaini\AppData\Local/Fortify
com.fortify.sca.Renderer=fpr
com.fortify.sca.RequireMapKeys=classrule
com.fortify.sca.ResultsFile=C:\AmersFiles\Gitworkspace\epds-auth\epds-auth_scan.fpr
com.fortify.sca.SolverTimeout=15
com.fortify.sca.SqlLanguage=TSQL

com.fortify.sca.SuppressLowSeverity=true
com.fortify.sca.ThreadCount.NameTableLoading=1
com.fortify.sca.ThreadCount.PreTransform=1
com.fortify.sca.TypeInferenceFunctionTimeout=60
com.fortify.sca.TypeInferenceLanguages=javascript,python,ruby
com.fortify.sca.TypeInferencePhase0Timeout=300
com.fortify.sca.UnicodeInputFile=true
com.fortify.sca.UniversalBlacklist=.*yyparse.*
com.fortify.sca.WrapperHeuristic=moderate
com.fortify.sca.analyzer.controlflow.EnableLivenessOptimization=false
com.fortify.sca.analyzer.controlflow.EnableMachineFiltering=false
com.fortify.sca.analyzer.controlflow.EnableRefRuleOptimization=false
com.fortify.sca.analyzer.controlflow.EnableTimeOut=true
com.fortify.sca.compilers.ant=com.fortify.sca.util.compilers.AntAdapter
com.fortify.sca.compilers.ar=com.fortify.sca.util.compilers.ArUtil
com.fortify.sca.compilers.armcc=com.fortify.sca.util.compilers.ArmCcCompiler
com.fortify.sca.compilers.armcpp=com.fortify.sca.util.compilers.ArmCppCompiler
com.fortify.sca.compilers.c++=com.fortify.sca.util.compilers.GppCompiler
com.fortify.sca.compilers.c89=com.fortify.sca.util.compilers.C89Compiler
com.fortify.sca.compilers.cc=com.fortify.sca.util.compilers.GccCompiler
com.fortify.sca.compilers.cl=com.fortify.sca.util.compilers.MicrosoftCompiler
com.fortify.sca.compilers.clearmake=com.fortify.sca.util.compilers.TouchlessCompiler
com.fortify.sca.compilers.devenv=com.fortify.sca.util.compilers.DevenvNetAdapter
com.fortify.sca.compilers.fortify=com.fortify.sca.util.compilers.FortifyCompiler
com.fortify.sca.compilers.g++=com.fortify.sca.util.compilers.GppCompiler
com.fortify.sca.compilers.g++-*=com.fortify.sca.util.compilers.GppCompiler
com.fortify.sca.compilers.g++2*=com.fortify.sca.util.compilers.GppCompiler
com.fortify.sca.compilers.g++3*=com.fortify.sca.util.compilers.GppCompiler
com.fortify.sca.compilers.g++4*=com.fortify.sca.util.compilers.GppCompiler
com.fortify.sca.compilers.gcc=com.fortify.sca.util.compilers.GccCompiler
com.fortify.sca.compilers.gcc-*=com.fortify.sca.util.compilers.GccCompiler
com.fortify.sca.compilers.gcc2*=com.fortify.sca.util.compilers.GccCompiler
com.fortify.sca.compilers.gcc3*=com.fortify.sca.util.compilers.GccCompiler
com.fortify.sca.compilers.gcc4*=com.fortify.sca.util.compilers.GccCompiler
com.fortify.sca.compilers.gmake=com.fortify.sca.util.compilers.TouchlessCompiler
com.fortify.sca.compilers.icc=com.fortify.sca.util.compilers.IntelCompiler
com.fortify.sca.compilers.icl=com.fortify.sca.util.compilers.MicrosoftCompiler
com.fortify.sca.compilers.icpc=com.fortify.sca.util.compilers.IntelCompiler
com.fortify.sca.compilers.jam=com.fortify.sca.util.compilers.TouchlessCompiler
com.fortify.sca.compilers.javac=com.fortify.sca.util.compilers.JavacCompiler
com.fortify.sca.compilers.ld=com.fortify.sca.util.compilers.LdCompiler
com.fortify.sca.compilers.link=com.fortify.sca.util.compilers.MicrosoftLinker
com.fortify.sca.compilers.make=com.fortify.sca.util.compilers.TouchlessCompiler
com.fortify.sca.compilers.msbuild=com.fortify.sca.util.compilers.MSBuildAdapter
com.fortify.sca.compilers.msdev=com.fortify.sca.util.compilers.DevenvAdapter
com.fortify.sca.compilers.mvn=com.fortify.sca.util.compilers.MavenAdapter
com.fortify.sca.compilers.nmake=com.fortify.sca.util.compilers.TouchlessCompiler
com.fortify.sca.compilers.tcc=com.fortify.sca.util.compilers.ArmCcCompiler
com.fortify.sca.compilers.tcpp=com.fortify.sca.util.compilers.ArmCppCompiler
com.fortify.sca.compilers.touchless=com.fortify.sca.util.compilers.FortifyCompiler
com.fortify.sca.compilers.xilink=com.fortify.sca.util.compilers.MicrosoftLinker

com.fortify.sca.cpfe.441.command=C:\Program Files\HP_Fortify\HP_Fortify_SCA_and_Apps_4.30\Core/private-bin/sca/cpfe441.rfct
com.fortify.sca.cpfe.command=C:\Program Files\HP_Fortify\HP_Fortify_SCA_and_Apps_4.30\Core/private-bin/sca/cpfe48.exe
com.fortify.sca.cpfe.file.option=--gen_c_file_name
com.fortify.sca.cpfe.options=--remove_unneeded_entities --suppress_vtbl -tused
com.fortify.sca.cpfe.options=--remove_unneeded_entities --suppress_vtbl -tused
com.fortify.sca.env.exesearchpath=C:\Users\mhussaini\Eclipse Luna With Git\eclipse;C:\Program Files\HP_Fortify\HP_Fortify_SCA_and_Apps_4.30\bin;C:\ProgramData\Oracle\Java\javapath;C:\WINDOWS\system32;C:\WINDOWS;C:\WINDOWS\System32\Wbem;C:\WINDOWS\System32\WindowsPowerShell\v1.0\;C:\Program Files (x86)\ActivIdentity\ActivClient\;C:\Program Files\ActivIdentity\ActivClient\;C:\WINDOWS\System32\WindowsPowerShell\v1.0\;C:\Users\mhussaini\apache-maven-3.3.9\bin;C:\Users\mhussaini\nodejs\;C:\Program Files (x86)\Riverbed\Steelhead Mobile\;C:\Program Files (x86)\PuTTY\;C:\Users\mhussaini\AppData\Local\atom\bin;C:\Users\mhussaini\AppData\Roaming\npm
com.fortify.sca.fileextensions.ABAP=ABAP
com.fortify.sca.fileextensions.abap=ABAP
com.fortify.sca.fileextensions.appxmanifest=XML
com.fortify.sca.fileextensions.as=ACTIONSCRIPT
com.fortify.sca.fileextensions.asp=ASP
com.fortify.sca.fileextensions.bas=VB6
com.fortify.sca.fileextensions.cfc=CFML
com.fortify.sca.fileextensions.cfm=CFML
com.fortify.sca.fileextensions.cfml=CFML
com.fortify.sca.fileextensions.cls=VB6
com.fortify.sca.fileextensions.config=XML
com.fortify.sca.fileextensions.cpx=XML
com.fortify.sca.fileextensions.cs=CSHARP
com.fortify.sca.fileextensions.cscfg=XML
com.fortify.sca.fileextensions.csdef=XML
com.fortify.sca.fileextensions.ctl=VB6
com.fortify.sca.fileextensions.ctp=PHP
com.fortify.sca.fileextensions.dll=MSIL
com.fortify.sca.fileextensions.erb=RUBY_ERB
com.fortify.sca.fileextensions.exe=MSIL
com.fortify.sca.fileextensions.faces=JSPX
com.fortify.sca.fileextensions.frm=VB6
com.fortify.sca.fileextensions.htm=HTML
com.fortify.sca.fileextensions.html=HTML
com.fortify.sca.fileextensions.ini=JAVA_PROPERTIES
com.fortify.sca.fileextensions.java=JAVA
com.fortify.sca.fileextensions.js=JAVASCRIPT
com.fortify.sca.fileextensions.jsff=JSPX
com.fortify.sca.fileextensions.jsp=JSP
com.fortify.sca.fileextensions.jspx=JSPX
com.fortify.sca.fileextensions.mdl=MSIL
com.fortify.sca.fileextensions.mod=MSIL
com.fortify.sca.fileextensions.mxml=MXML
com.fortify.sca.fileextensions.php=PHP
com.fortify.sca.fileextensions.phtml=PHP
com.fortify.sca.fileextensions.pkb=PLSQL
com.fortify.sca.fileextensions.pkh=PLSQL
com.fortify.sca.fileextensions.pks=PLSQL

com.fortify.sca.fileextensions.plist=XML
com.fortify.sca.fileextensions.properties=JAVA_PROPERTIES
com.fortify.sca.fileextensions.py=PYTHON
com.fortify.sca.fileextensions.rb=RUBY
com.fortify.sca.fileextensions.settings=XML
com.fortify.sca.fileextensions.sql=SQL
com.fortify.sca.fileextensions.tag=JSP
com.fortify.sca.fileextensions.tagx=JSP
com.fortify.sca.fileextensions.tld=TLD
com.fortify.sca.fileextensions.vb=VB
com.fortify.sca.fileextensions.vbs=VBSCRIPT
com.fortify.sca.fileextensions.vbscript=VBSCRIPT
com.fortify.sca.fileextensions.wadcfg=XML
com.fortify.sca.fileextensions.wsdd=XML
com.fortify.sca.fileextensions.wsdl=XML
com.fortify.sca.fileextensions.xcfg=XML
com.fortify.sca.fileextensions.xhtml=JSPX
com.fortify.sca.fileextensions.xmi=XML
com.fortify.sca.fileextensions.xml=XML
com.fortify.sca.fileextensions.xsd=XML
com.fortify.sca.jsp.UseNativeParser=true
com.fortify.sca.parser.python.ignore.module.1=test.badsyntax_future3
com.fortify.sca.parser.python.ignore.module.2=test.badsyntax_future4
com.fortify.sca.parser.python.ignore.module.3=test.badsyntax_future5
com.fortify.sca.parser.python.ignore.module.4=test.badsyntax_future6
com.fortify.sca.parser.python.ignore.module.5=test.badsyntax_future7
com.fortify.sca.parser.python.ignore.module.6=test.badsyntax_future8
com.fortify.sca.parser.python.ignore.module.7=test.badsyntax_future9
com.fortify.sca.parser.python.ignore.module.8=test.badsyntax_nocaret
com.fortify.search.defaultSyntaxVer=2
com.sun.management.jmxremote=true
dotnet.install.dir=C:\Windows\Microsoft.NET\Framework64
dotnet.v30.referenceAssemblies=C:\Program Files\Reference Assemblies\Microsoft\Framework\v3.0
dotnet.v35.referenceAssemblies=C:\Program Files\Reference Assemblies\Microsoft\Framework\v3.5
file.encoding=Cp1252
file.encoding.pkg=sun.io
file.separator=\
java.awt.graphicsenv=sun.awt.Win32GraphicsEnvironment
java.awt.headless=true
java.awt.printerjob=sun.awt.windows.WPrinterJob
java.class.path=C:\Program Files\HP_Fortify\HP_Fortify_SCA_and_Apps_4.30\Core\lib\exe\sca-exe.jar
java.class.version=51.0
java.endorsed.dirs=C:\Program Files\HP_Fortify\HP_Fortify_SCA_and_Apps_4.30\jre\lib\endorsed
java.ext.dirs=C:\Program Files\HP_Fortify\HP_Fortify_SCA_and_Apps_4.30\jre\lib\ext;C:\WINDOWS\Sun\Java\lib\ext
java.home=C:\Program Files\HP_Fortify\HP_Fortify_SCA_and_Apps_4.30\jre
java.io.tmpdir=C:\Users\MHUSSA~1\AppData\Local\Temp\1\
java.library.path=C:\Program Files\HP_Fortify\HP_Fortify_SCA_and_Apps_4.30\jre\bin;C:\WINDOWS\Sun\Java\bin;C:\WINDOWS\system32;C:\WINDOWS;C:\Program Files\HP_Fortify\HP_Fortify_SCA_and_Apps_4.30\bin;C:\ProgramData\Oracle\Java\javapath;C:\WINDOWS\system32;C:\WINDOWS;C:\WINDOWS\System32\Wbem;C:\WINDOWS\System32\WindowsPowerShell\v1.0\;C:\Program Files

(x86)\ActivIdentity\ActivClient\;C:\Program Files\ActivIdentity\ActivClient\;C:\WINDOWS\System32\WindowsPowerShell\v1.0\;C:\Users\mhussaini\apache-maven-3.3.9\bin;C:\Users\mhussaini\nodejs\;C:\Program Files (x86)\Riverbed\Steelhead Mobile\;C:\Program Files (x86)\PuTTY\;C:\Users\mhussaini\AppData\Local\atom\bin;C:\Users\mhussaini\AppData\Roaming\npm;.
java.rmi.server.randomIDs=true
java.runtime.name=Java(TM) SE Runtime Environment
java.runtime.version=1.7.0_45-b18
java.specification.name=Java Platform API Specification
java.specification.vendor=Oracle Corporation
java.specification.version=1.7
java.vendor=Oracle Corporation
java.vendor.url=http://java.oracle.com/
java.vendor.url.bug=http://bugreport.sun.com/bugreport/
java.version=1.7.0_45
java.vm.info=mixed mode
java.vm.name=Java HotSpot(TM) 64-Bit Server VM
java.vm.specification.name=Java Virtual Machine Specification
java.vm.specification.vendor=Oracle Corporation
java.vm.specification.version=1.7
java.vm.vendor=Oracle Corporation
java.vm.version=24.45-b08
line.separator=

max.file.path.length=255
os.arch=amd64
os.name=Windows 7
os.version=6.1
path.separator=;
stderr.isatty=false
stdout.isatty=false
sun.arch.data.model=64
sun.boot.class.path=C:\Program Files\HP_Fortify\HP_Fortify_SCA_and_Apps_4.30\jre\lib\resources.jar;C:\Program Files\HP_Fortify\HP_Fortify_SCA_and_Apps_4.30\jre\lib\rt.jar;C:\Program Files\HP_Fortify\HP_Fortify_SCA_and_Apps_4.30\jre\lib\sunrsasign.jar;C:\Program Files\HP_Fortify\HP_Fortify_SCA_and_Apps_4.30\jre\lib\jsse.jar;C:\Program Files\HP_Fortify\HP_Fortify_SCA_and_Apps_4.30\jre\lib\jce.jar;C:\Program Files\HP_Fortify\HP_Fortify_SCA_and_Apps_4.30\jre\lib\charsets.jar;C:\Program Files\HP_Fortify\HP_Fortify_SCA_and_Apps_4.30\jre\lib\jfr.jar;C:\Program Files\HP_Fortify\HP_Fortify_SCA_and_Apps_4.30\jre\classes
sun.boot.library.path=C:\Program Files\HP_Fortify\HP_Fortify_SCA_and_Apps_4.30\jre\bin
sun.cpu.endian=little
sun.cpu.isalist=amd64
sun.desktop=windows
sun.io.unicode.encoding=UnicodeLittle
sun.java.command=C:\Program Files\HP_Fortify\HP_Fortify_SCA_and_Apps_4.30\Core\lib\exe\sca-exe.jar -scan -pid-file C:\Users\MHUSSA~1\AppData\Local\Temp\1\PID205445936769652370.tmp @C:\Users\mhussaini\AppData\Local\Fortify\Eclipse.Plugin-4.30\C__Users_mhussaini_Gitworkspace_epds-auth\epds-authScan.txt
sun.java.launcher=SUN_STANDARD
sun.jnu.encoding=Cp1252
sun.management.compiler=HotSpot 64-Bit Tiered Compilers

sun.os.patch.level=Service Pack 1
user.country=US
user.dir=C:\Users\mhussaini\Eclipse Luna With Git\eclipse
user.home=C:\Users\mhussaini
user.language=en
user.name=MHussaini
user.script=
user.timezone=America/Denver
user.variant=
win32.LocalAppdata=C:\Users\mhussaini\AppData\Local

Commandline Arguments

-scan
-pid-file
C:\Users\MHUSSA~1\AppData\Local\Temp\1\PID205445936769652370.tmp
-b
epds-auth
-machine-output
-format
fpr
-f
C:\AmersFiles\Gitworkspace\epds-auth\epds-auth_scan.fpr

Warnings

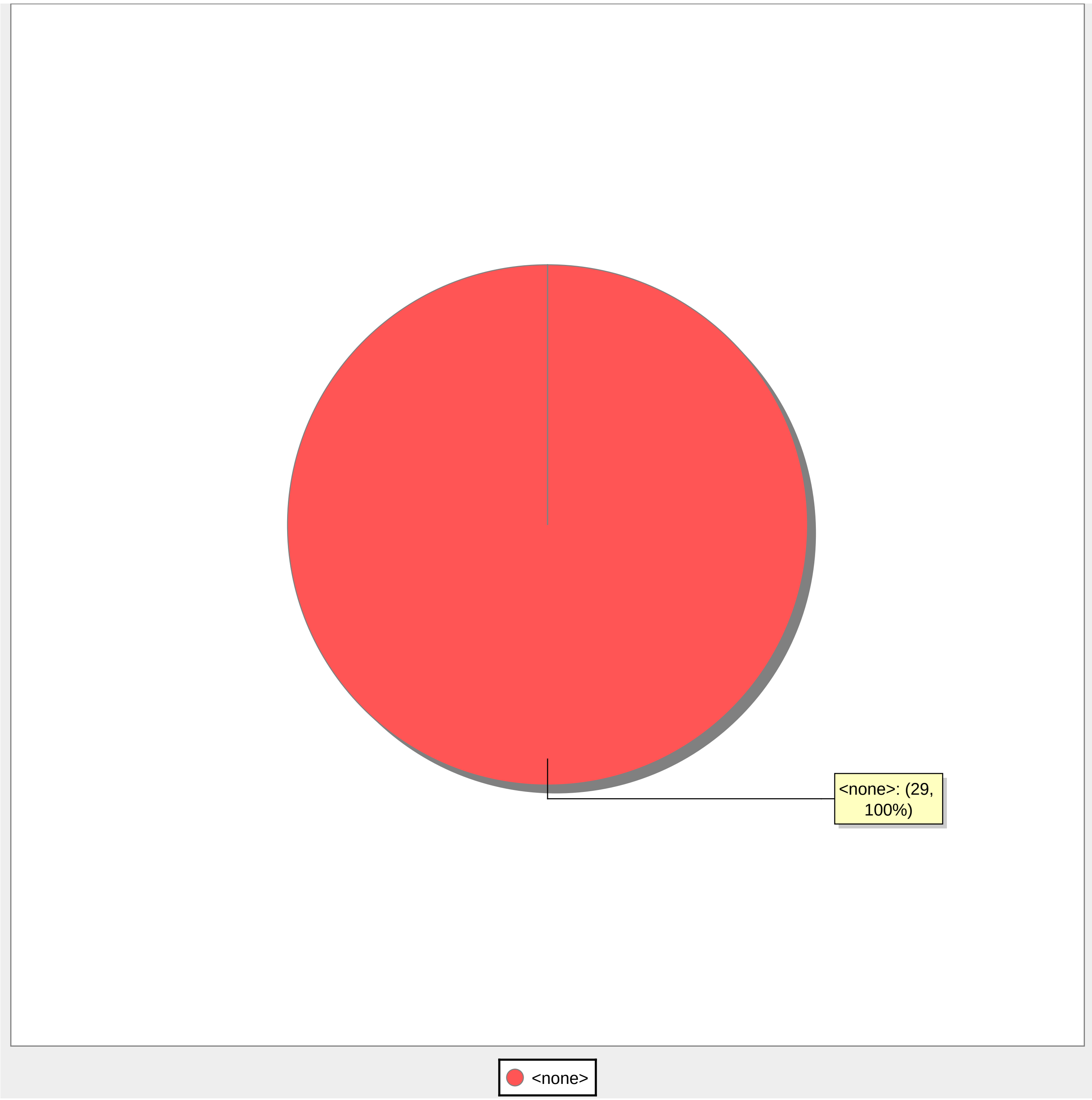
[236] Your license does not allow access to Fortify SCA for Python

Issue Count by Category

Issues by Category	
Privacy Violation	10
Privacy Violation: Heap Inspection	8
Password Management: Empty Password in Configuration File	4
Password Management: Password in Configuration File	4
Insecure Transport: Mail Transmission	1
Log Forging	1
Password Management: Hardcoded Password	1

Issue Breakdown by Analysis

Issues by Analysis



New Issues

Issues by New Issue

The following issues have been discovered since the last scan.